CLEANCITY

TASK 2 — VULNERABILITY ASSESSMENT

DVWA Web Application Security Testing Report

Project	CleanCity Penetration Testing
Target	Damn Vulnerable Web Application (DVWA)
Target URL	http://127.0.0.1/DVWA/
Environment	Local Ubuntu VM / Apache
Manual tool	Burp Suite Community Edition
Automated tool	Nikto 2.1.5
Browser / proxy	Firefox with FoxyProxy
Assessment date	14 November 2026
Assessment type	Authorized local training-lab assessment

Prepared for management review

1. Executive Summary

A controlled security assessment was conducted against a locally hosted DVWA instance. Manual testing in Burp Suite demonstrated SQL Injection, Reflected Cross-Site Scripting (XSS), Stored XSS and predictable values in the DVWA Weak Session IDs exercise. Nikto 2.1.5 additionally reported web-server configuration and information-disclosure observations.

The directory-listing issue was investigated and an Apache configuration change was applied. The tested /DVWA/config/ path subsequently returned **403 Forbidden** instead of a file listing. Other scanner-reported paths still require individual retesting.

Scope limitation: DVWA is intentionally vulnerable training software. These results apply only to the local lab target and are not evidence that CleanCity production infrastructure or any unrelated system is vulnerable. Severity labels are qualitative recommendations, not externally validated CVSS scores.

2. Scope and Environment

• Target application: DVWA at http://127.0.0.1/DVWA/.

• Target host: local Ubuntu virtual machine running Apache.

• DVWA security level: Low, for controlled demonstrations.

• Tools: Burp Suite Community Edition, Firefox/FoxyProxy and Nikto 2.1.5.

• Scope: selected DVWA modules and local Apache configuration only; no external or production hosts were tested.

3. Methodology

• Started Apache and confirmed DVWA was reachable.

• Set DVWA security level to Low.

• Configured Firefox/FoxyProxy to route traffic through Burp and verified interception.

• Captured baseline requests and used Burp Repeater to inspect controlled test inputs and responses.

• Reviewed browser storage for dvwaSession values generated by the Weak Session IDs module.

• Installed and verified Nikto 2.1.5, then scanned the local DVWA URL.

• Investigated directory indexing, changed Apache configuration, tested syntax and verified the affected path returned 403 Forbidden.

4. Findings at a Glance

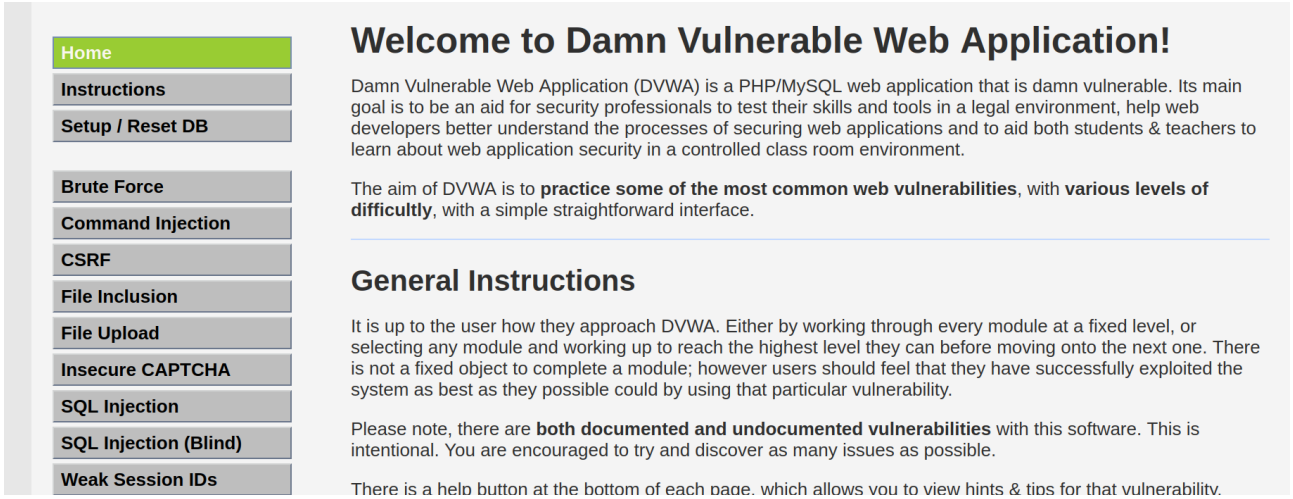
ID	Finding	Evidence summary	Severity	Status
VA-01	SQL Injection	Modified ID returned admin record	High	Demonstrated
VA-02	Reflected XSS	Script reflected in response	Medium	Demonstrated
VA-03	Stored XSS	Stored guestbook payload appeared	High	Demonstrated
VA-04	Weak Session IDs	dvwaSession sequence 5, 6, 7 (notes also recorded 8)	Medium	DVWA module
VA-05	Directory listing	Files listed; tested path later returned 403	Medium	Partial fix
VA-06	Missing HttpOnly	Nikto reported two cookies without flag	Medium	Retest pending
VA-07	Missing framing header	No X-Frame-Options reported	Low	Retest pending
VA-08	Server / ETag disclosure	Apache banner and inode metadata	Low / Info	Retest pending

5. Lab Setup and Traffic Interception

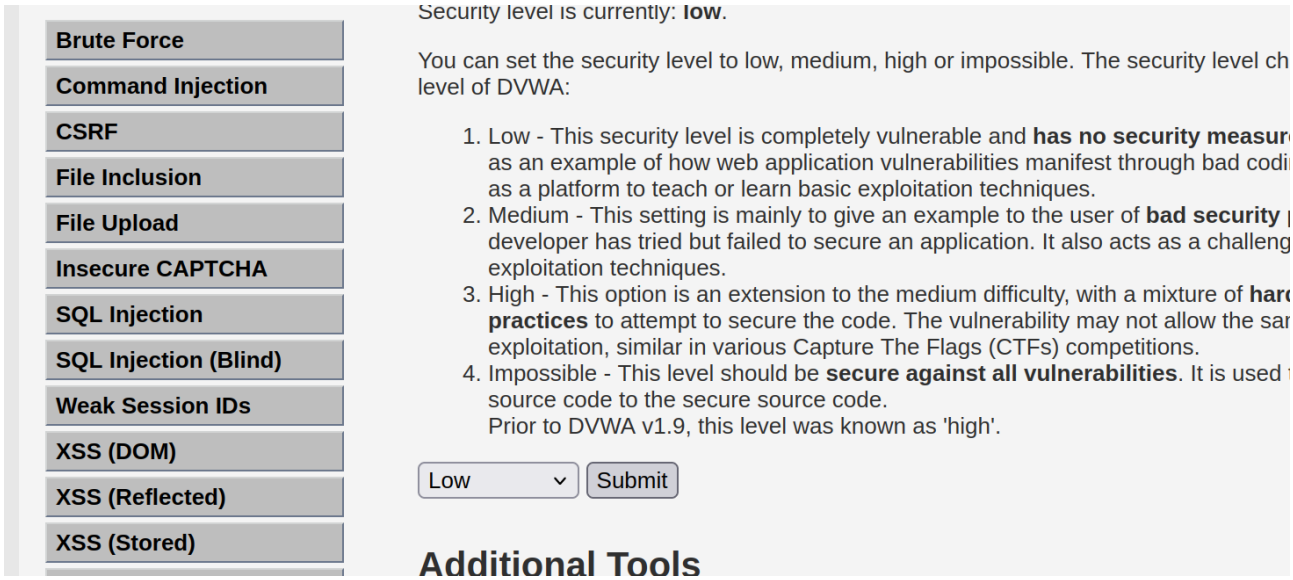
The following evidence records the lab service startup, DVWA availability, security-level selection and proxy configuration used before the vulnerability tests.

```
intern@ubunto:~$ sudo systemctl start apache2
intern@ubunto:~$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
     Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor prese>
     Active: active (running) since Sat 2026-11-14 19:48:49 PKT; 13min ago
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 948 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUC>
   Main PID: 1020 (apache2)
      Tasks: 6 (limit: 4548)
     Memory: 15.1M
        CPU: 237ms
     CGroup: /system.slice/apache2.service
             ├─1020 /usr/sbin/apache2 -k start
             ├─1073 /usr/sbin/apache2 -k start
             ├─1074 /usr/sbin/apache2 -k start
             ├─1084 /usr/sbin/apache2 -k start
             ├─1085 /usr/sbin/apache2 -k start
             └─1092 /usr/sbin/apache2 -k start
```

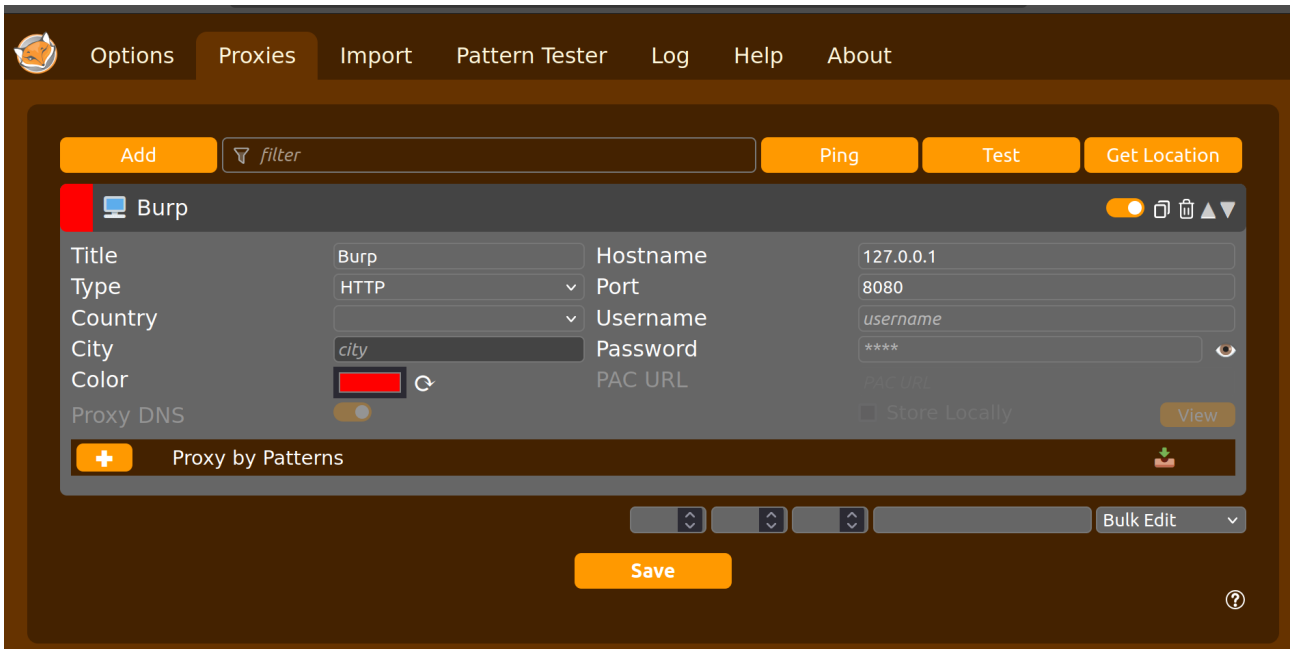
Starting Apache on the Ubuntu lab machine.



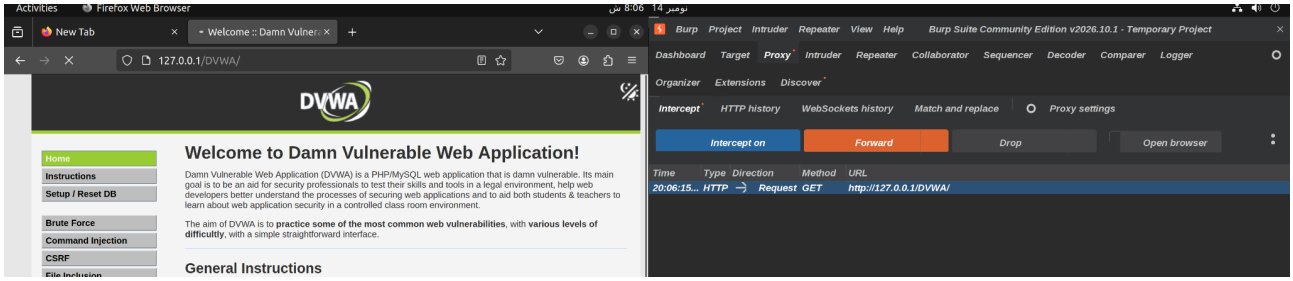
DVWA dashboard confirming the target application was available.



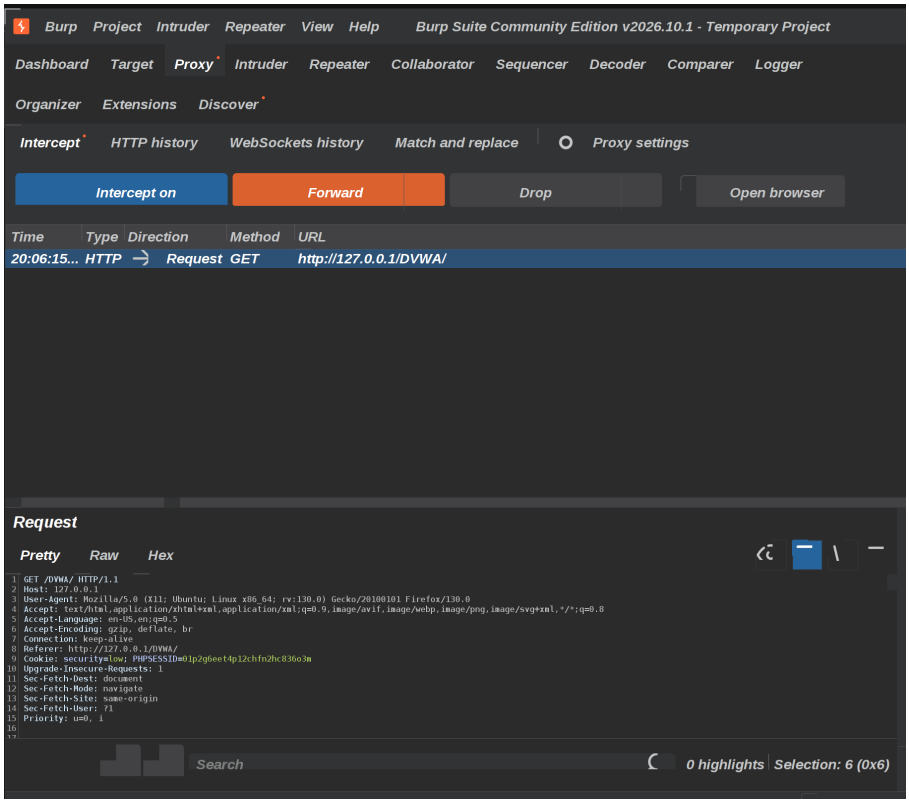
DVWA security level set to Low for the controlled lab exercises.



Firefox proxy configuration for Burp Suite.



Burp Proxy successfully intercepting browser requests.



Burp Suite Proxy interface used during request inspection.

VA-01 — SQL Injection

Suggested severity: High **Affected module: /DVWA/vulnerabilities/sqli/**

Description and test result: SQL Injection occurs when untrusted input is inserted into a database query without safe parameterization. The User ID field was modified with the controlled test value `1\' OR \'1\'=\'1\' #`. Burp was used to inspect the request and response. The application returned a record showing first name and surname as admin, demonstrating that the input altered the intended query logic.

Potential impact: Potential impact: depending on query structure and database permissions, an attacker may expose records or perform unauthorized database operations.

Recommended remediation:

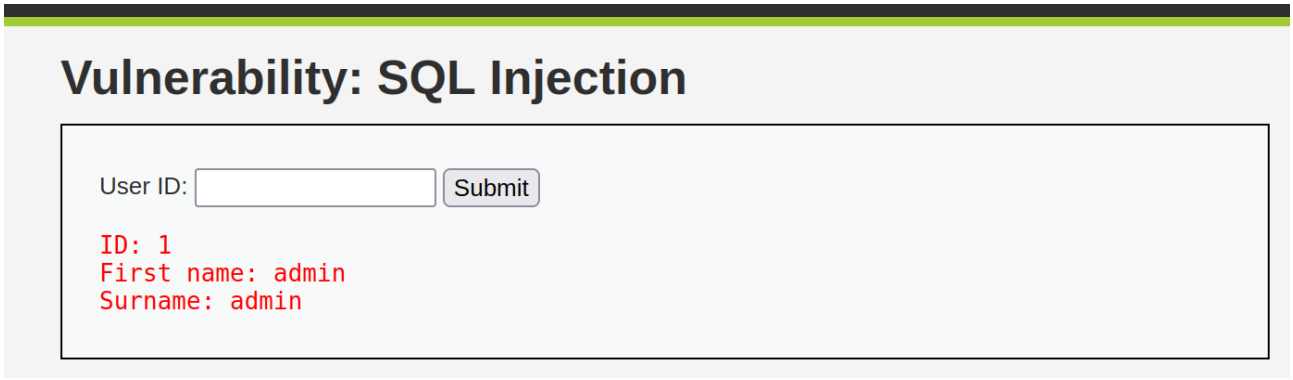
• Use prepared statements and parameterized queries.

• Validate expected input type and range.

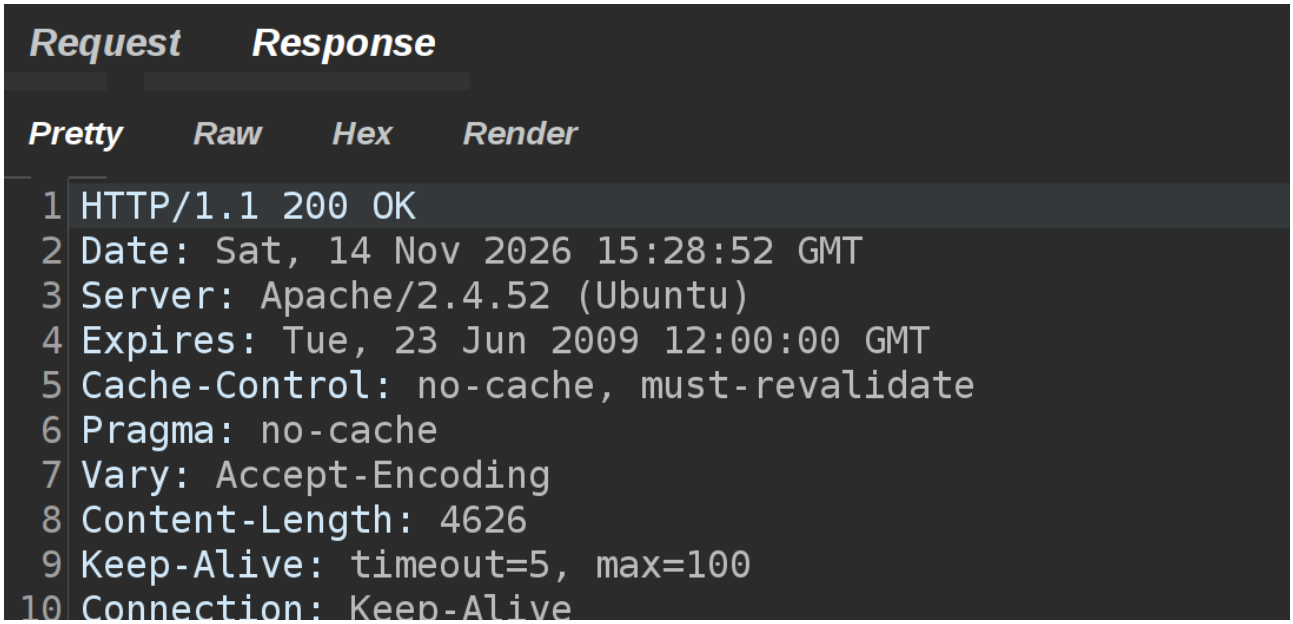
• Never concatenate raw user input into SQL.

• Use least-privilege database accounts and safe error handling.

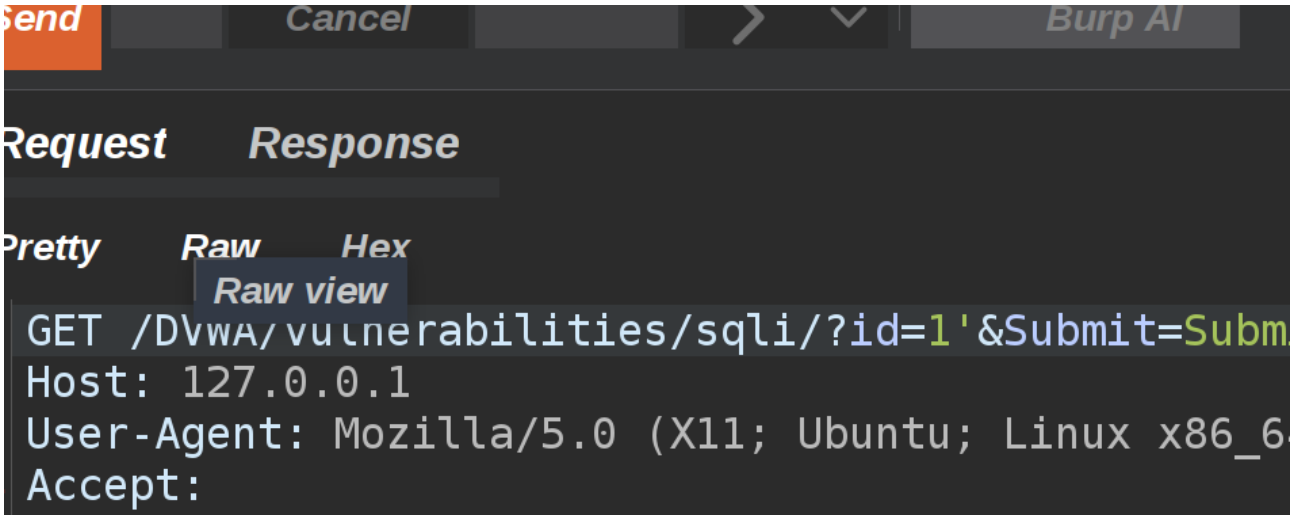
Evidence screenshots:



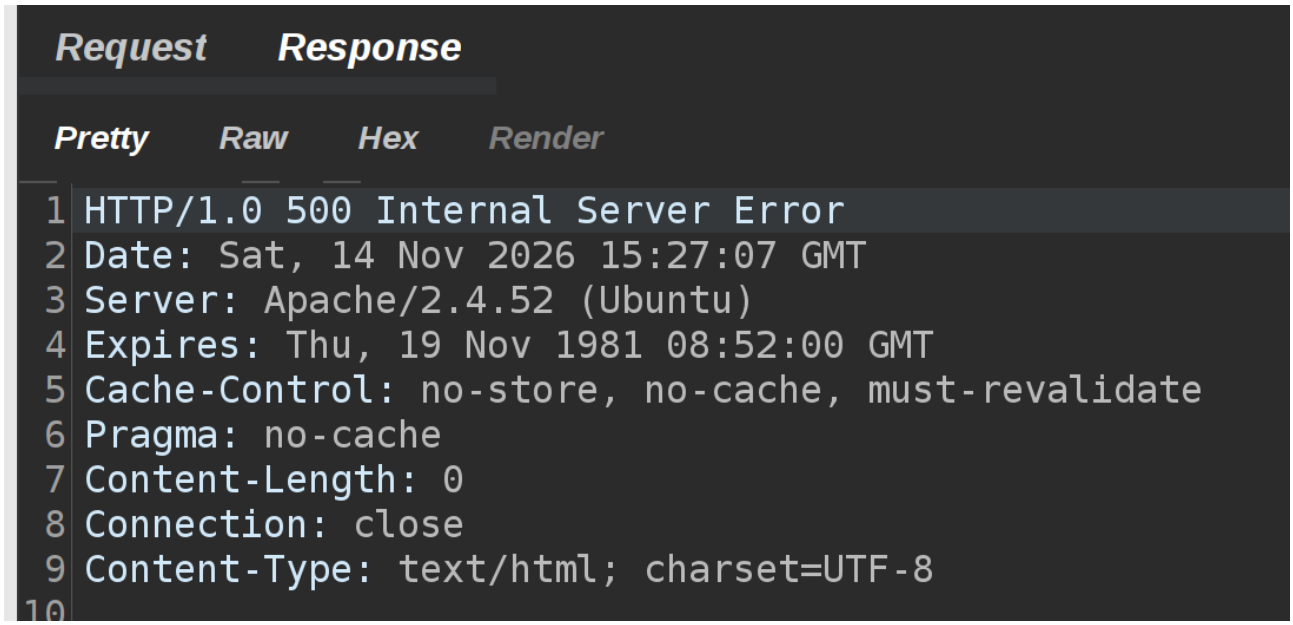
Baseline application request.



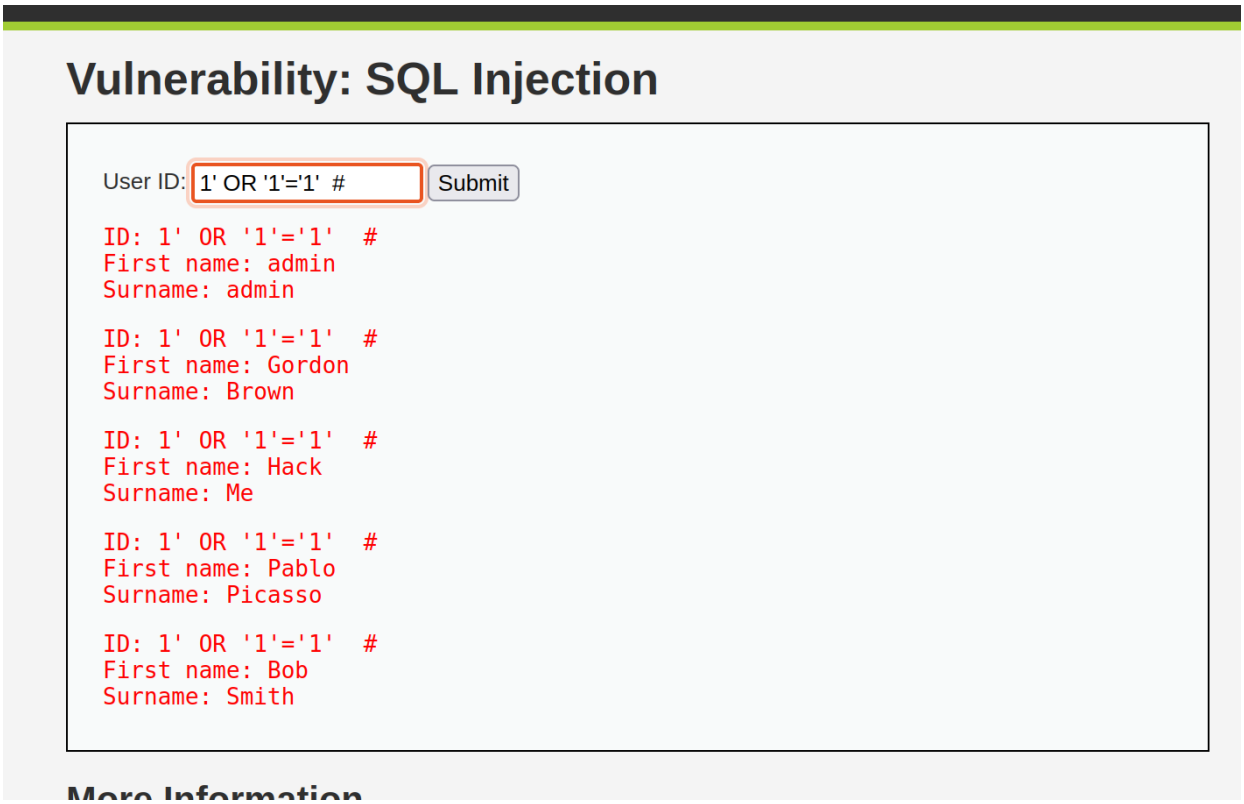
Baseline response inspected in Burp Repeater.



Modified SQL Injection request.



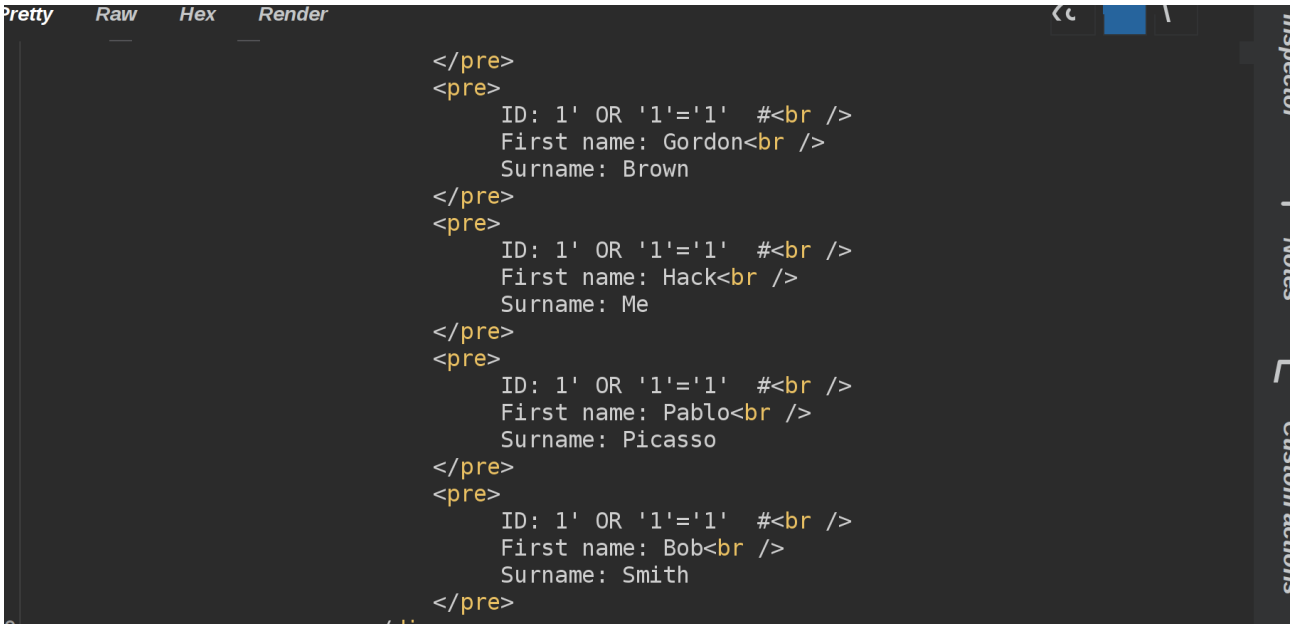
Response after submitting the modified input.



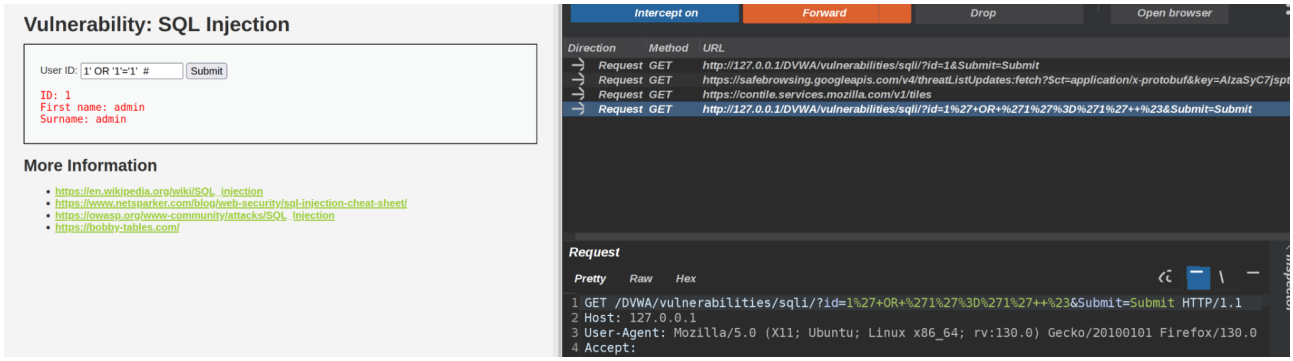
Database response showing multiple records, including admin.



Burp request associated with the SQL Injection test.



Burp response showing returned database records.



DVWA SQL Injection page and related Burp evidence.

VA-02 — Reflected Cross-Site Scripting (XSS)

Suggested severity: Medium **Affected module: /DVWA/vulnerabilities/xss_r/**

Description and test result: Reflected XSS occurs when user input is included in the immediate response without context-aware output encoding. The controlled payload was `<script>alert(\'XSS by Hafiz\')</script>`. Burp evidence showed the script markup reflected in the response HTML; browser-side execution was demonstrated during the lab test.

Potential impact: Potential impact: a crafted link or attacker-controlled input may cause JavaScript to execute in a victim browser under the vulnerable site origin.

Recommended remediation:

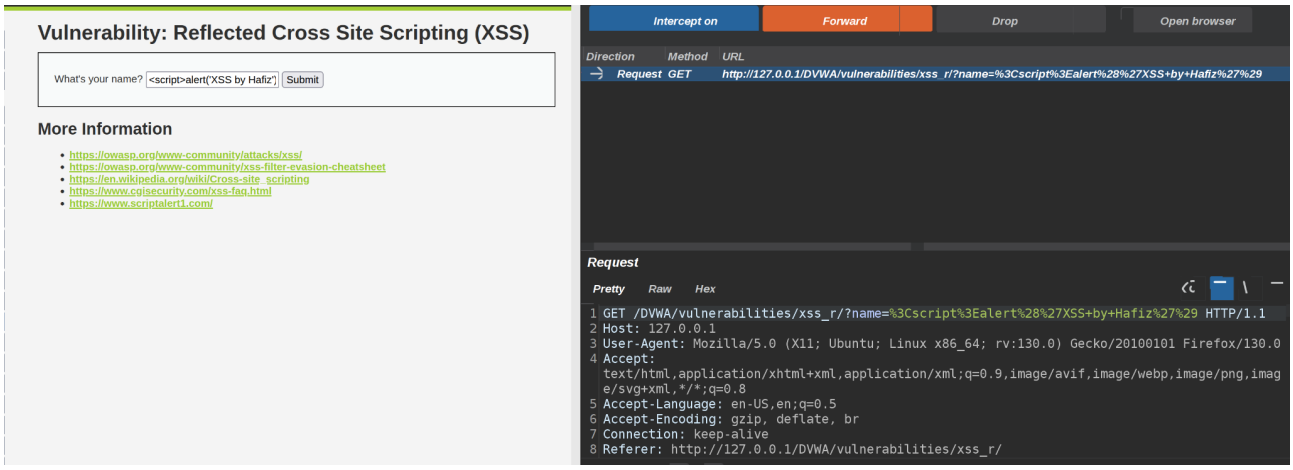
• Contextually encode untrusted output before rendering HTML.

• Avoid inserting untrusted values into executable HTML or JavaScript contexts.

• Use a restrictive Content Security Policy as defense in depth.

• Do not rely on input filtering alone.

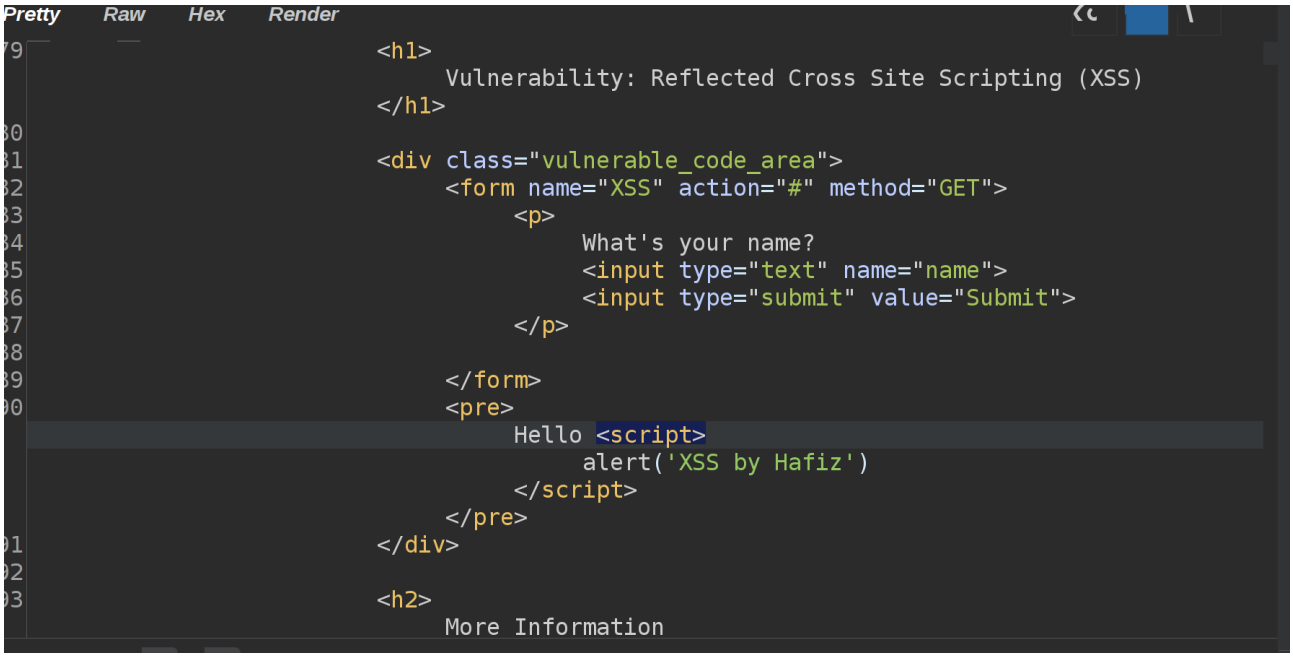
Evidence screenshots:



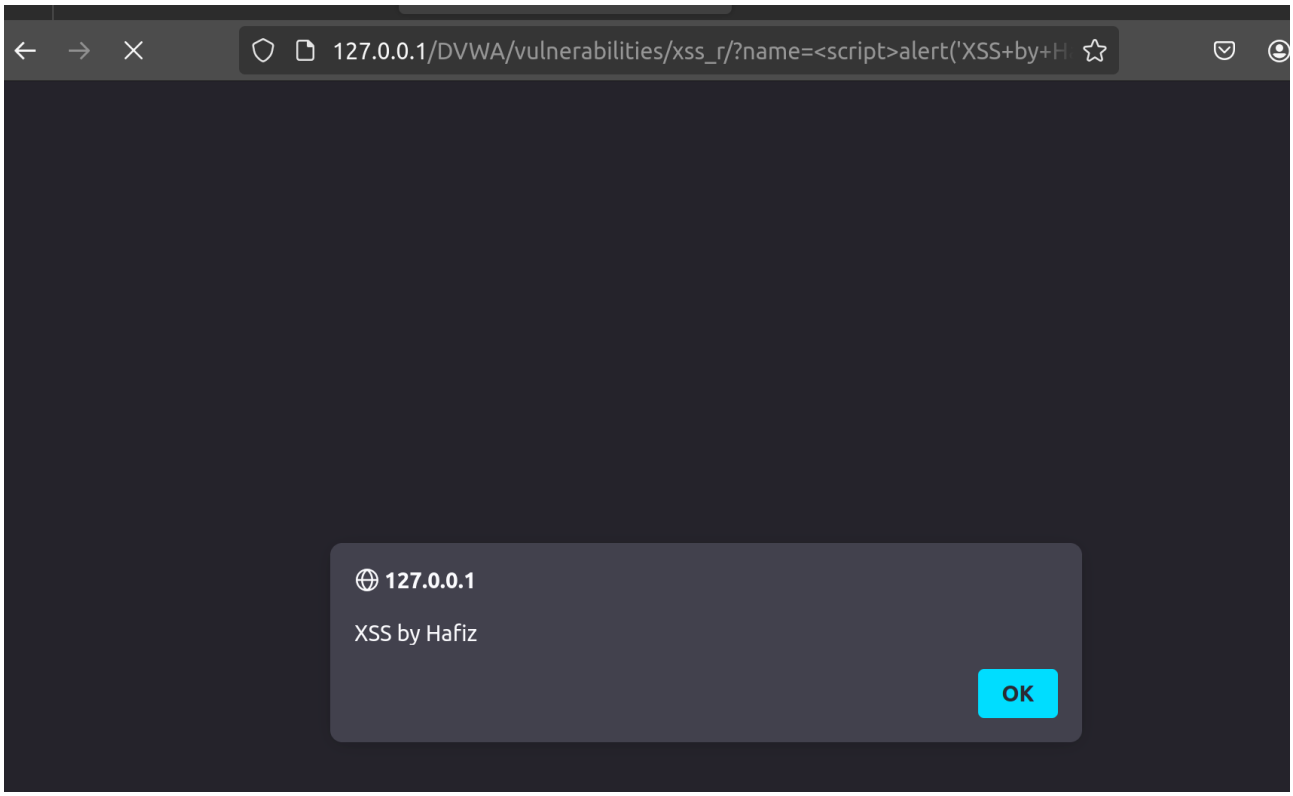
Capturing the Reflected XSS request.



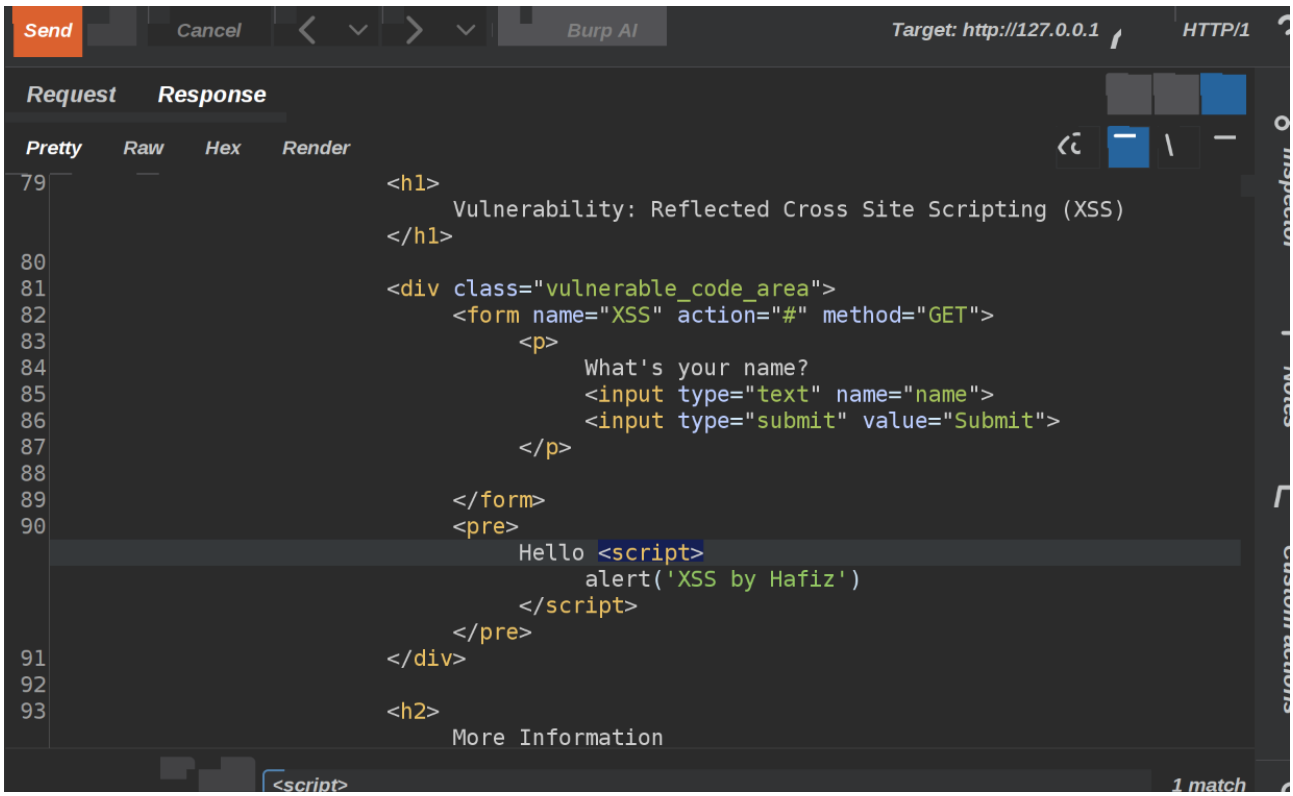
Reflected XSS payload submitted through Burp.



Response containing the reflected script markup.



Browser-side evidence from the Reflected XSS test.



Additional Reflected XSS response evidence.

VA-03 — Stored Cross-Site Scripting (XSS)

Suggested severity: High **Affected module: /DVWA/vulnerabilities/xss_s/**

Description and test result: Stored XSS occurs when attacker-controlled content is saved and later displayed without safe output encoding. A guestbook entry used `<script>alert(\'Stored XSS by Hafiz\')</script>`. Burp response evidence showed the payload in the guestbook output, and the practical browser test demonstrated the stored behavior.

Potential impact: Potential impact: the payload may execute for every user who views the affected content, depending on page access and visibility.

Recommended remediation:

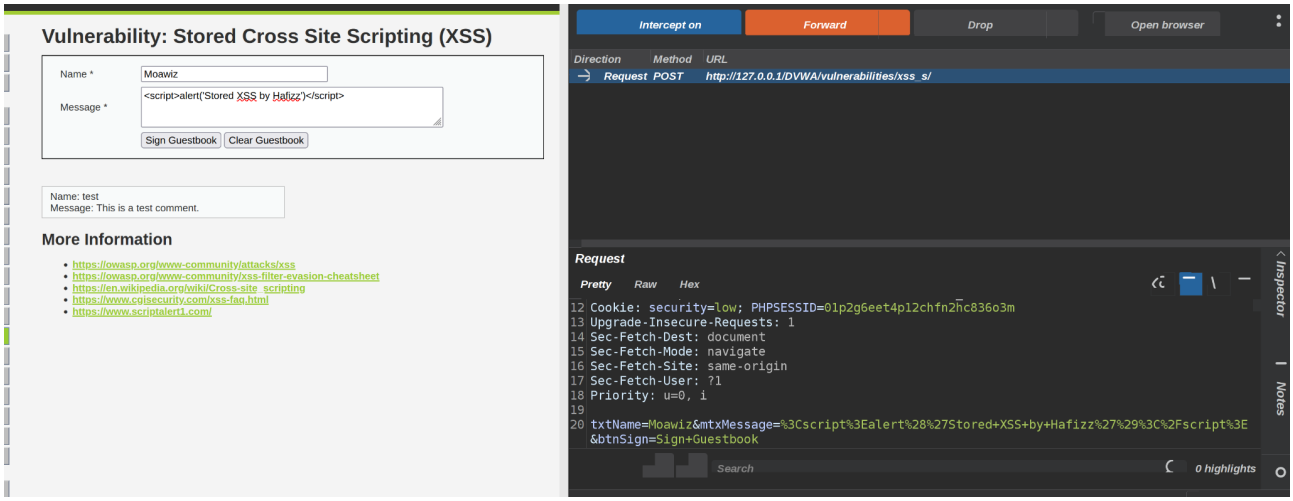
• Encode untrusted content whenever it is rendered.

• If HTML input is required, sanitize it with a maintained allow-list sanitizer.

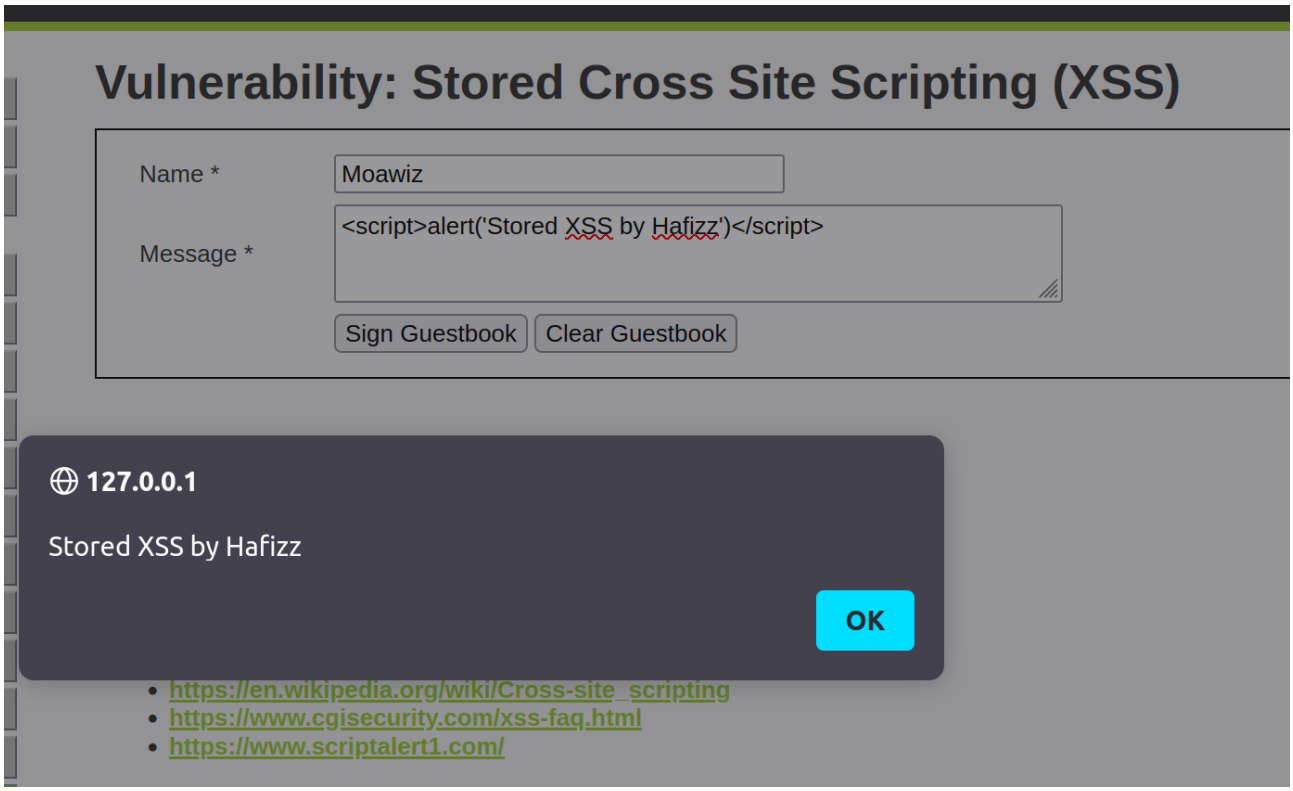
• Apply input length limits and a restrictive Content Security Policy.

• Review and safely remove malicious stored entries.

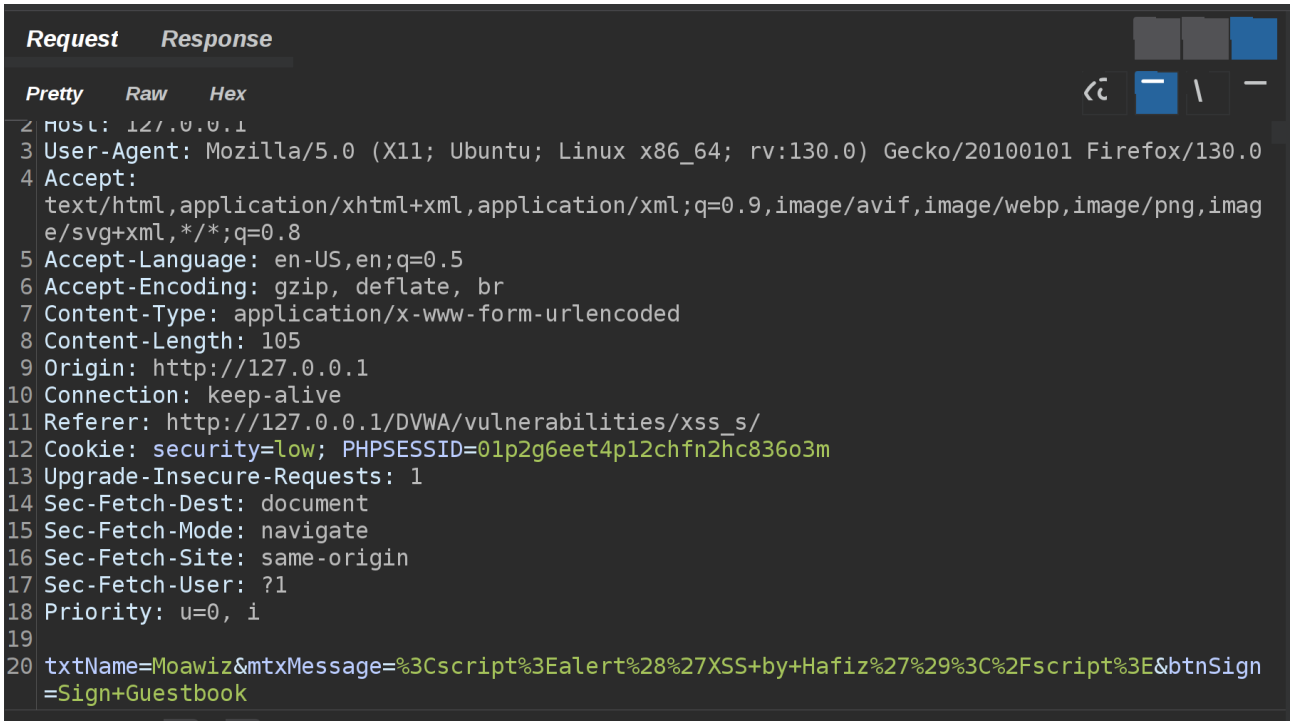
Evidence screenshots:



Capturing the guestbook submission.



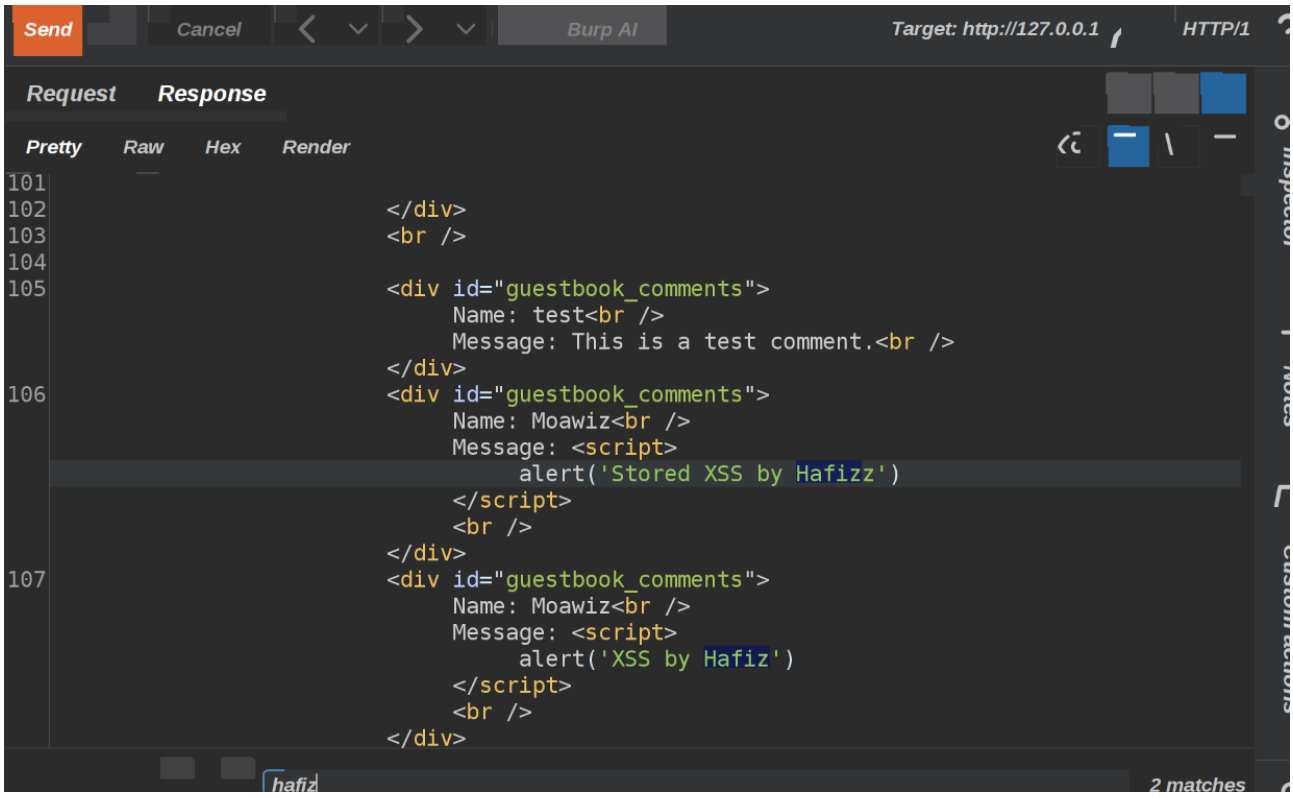
Stored payload behavior observed in the browser.



Burp request used to submit the guestbook payload.



Burp response showing the stored payload.



Additional Stored XSS response evidence.

VA-04 — Weak Session IDs

Suggested severity: Medium **Affected module: /DVWA/vulnerabilities/weak_id/**

Description and test result: The DVWA Weak Session IDs exercise sets a cookie named dvwaSession when Generate is clicked. The screenshots show values 5, 6 and 7; the practical notes also recorded 8. This is a sequential and predictable sequence in the DVWA exercise. It is separate from the application PHPSESSID cookie.

Potential impact: Potential impact: predictable session identifiers in a real application may be guessable. This evidence demonstrates predictable values in the DVWA module only; it does not independently prove PHPSESSID compromise or account takeover.

Recommended remediation:

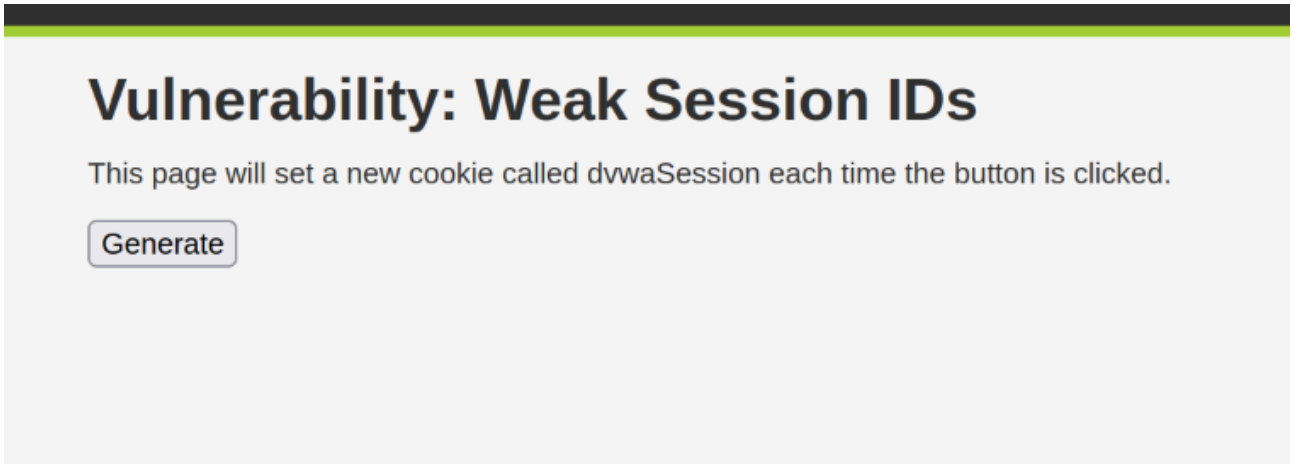
• Generate identifiers with a cryptographically secure random number generator.

• Use sufficiently long and unpredictable tokens.

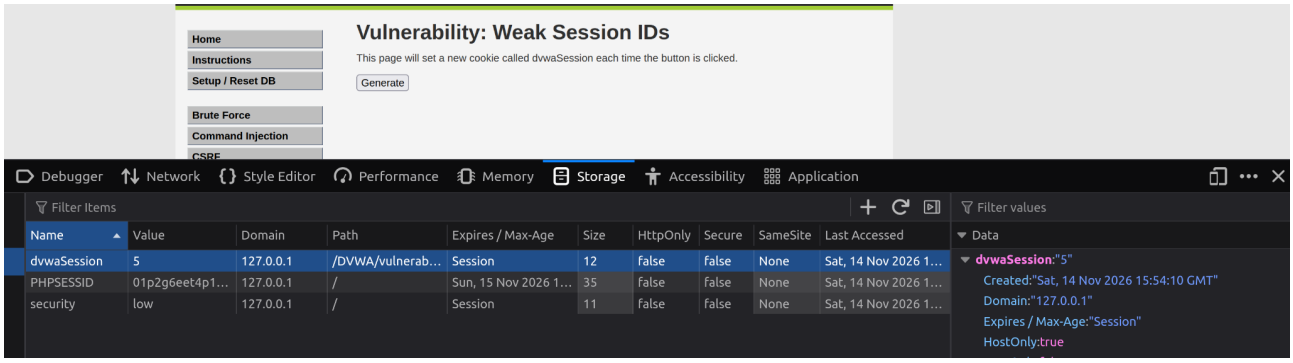
• Regenerate identifiers after login and privilege changes.

• Expire sessions on logout/inactivity and apply suitable cookie attributes.

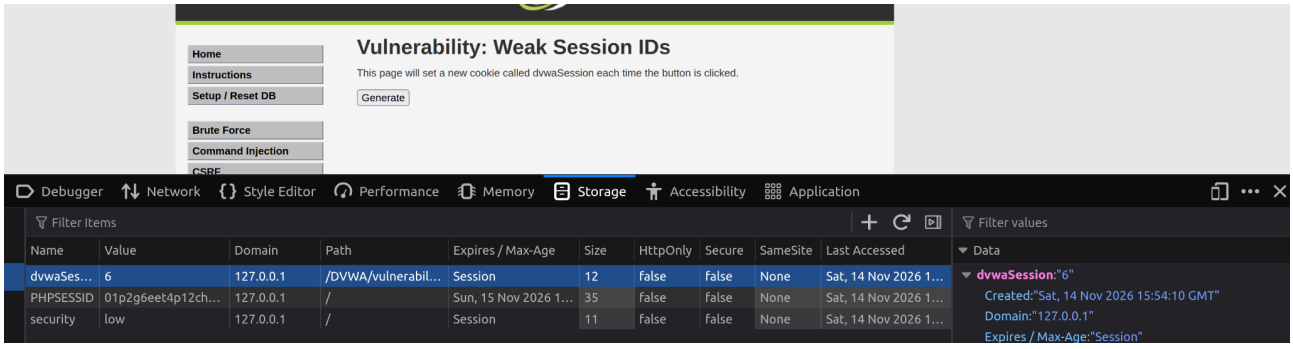
Evidence screenshots:



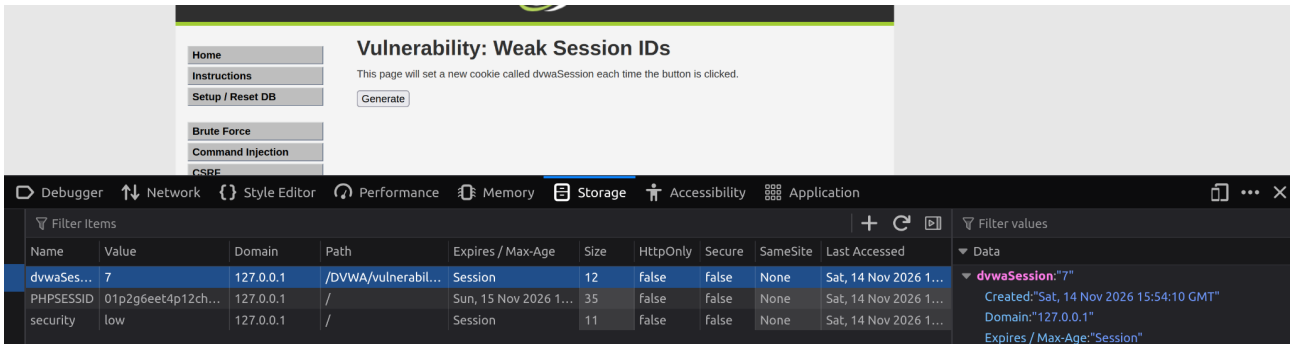
Weak Session IDs module and Generate control.



First observed dvwaSession value: 5.



Second observed value: 6.



Third observed value: 7.

VA-05 — Directory Listing / Security Misconfiguration

Suggested severity: Medium **Affected path: /DVWA/config/; Nikto also reported /tests/, /database/ and /docs/**

Description and test result: Directory indexing displays files when a directory has no index page. Nikto reported indexing on /DVWA/config/, /DVWA/tests/, /DVWA/database/ and /DVWA/docs/. The browser initially displayed filenames in /DVWA/config/, including config.inc.php and backup/distribution variants. Apache was configured with Options -Indexes for the DVWA directory. apache2ctl configtest returned Syntax OK, and the tested /DVWA/config/ path then returned 403 Forbidden.

Potential impact: Potential impact: listings disclose application structure and filenames; exposed backup/configuration files may reveal sensitive details. The fix was verified only for /DVWA/config/. Other reported paths and direct file URLs need separate retesting.

Recommended remediation:

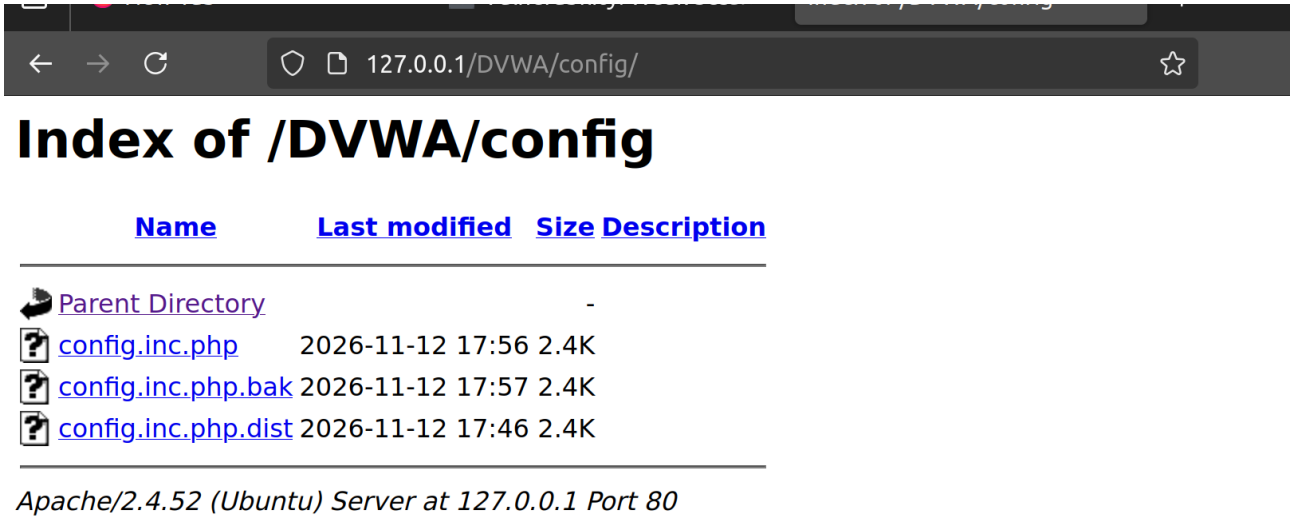
• Disable directory indexing at the correct Apache directory scope.

• Deny direct access to configuration, backup and development files.

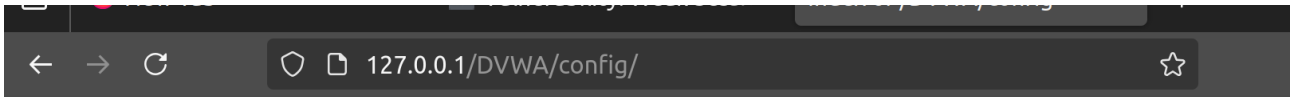
• Store secrets outside the web document root where possible.

• Retest every reported path and direct file access after remediation.

Evidence screenshots:



Initial verification of directory-listing exposure.

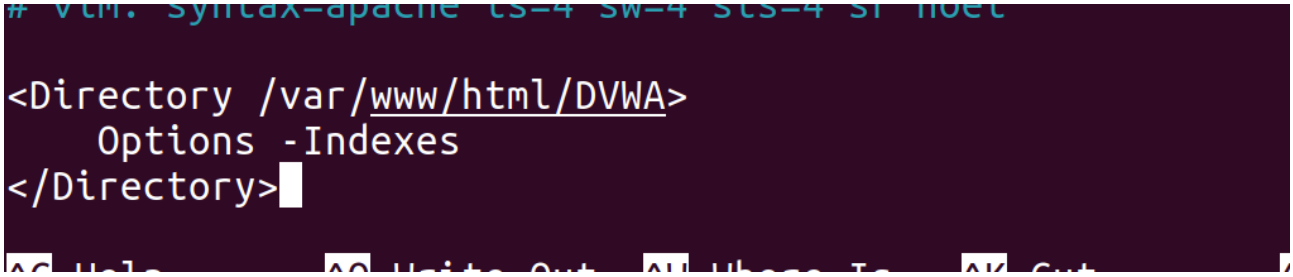


Index of /DVWA/config

Name	Last modified	Size	Description
Parent Directory		-	
config.inc.php	2026-11-12 17:56	2.4K	
config.inc.php.bak	2026-11-12 17:57	2.4K	
config.inc.php.dist	2026-11-12 17:46	2.4K	

Apache/2.4.52 (Ubuntu) Server at 127.0.0.1 Port 80

Initial /DVWA/config/ listing and exposed filenames.



Apache configuration change using Options -Indexes.



Apache configuration test completed with Syntax OK.



Forbidden

You don't have permission to access this resource.

Apache/2.4.52 (Ubuntu) Server at 127.0.0.1 Port 80

Retest result after applying the configuration change.



Forbidden

You don't have permission to access this resource.

Apache/2.4.52 (Ubuntu) Server at 127.0.0.1 Port 80

Browser confirmation of 403 Forbidden.

VA-06 — Missing HttpOnly Cookie Attribute

Suggested severity: Medium **Cookies: security and PHPSESSID**

Description and test result: Nikto reported that the security and PHPSESSID cookies were created without the HttpOnly flag. HttpOnly prevents ordinary client-side JavaScript from reading a cookie and is an important defense-in-depth measure when XSS is present.

Potential impact: Potential impact: if script executes in the site origin, a cookie without HttpOnly may be readable by that script. HttpOnly does not prevent XSS itself.

Recommended remediation:

• Set HttpOnly on session cookies.

• Set Secure when the application is served over HTTPS.

• Choose an appropriate SameSite policy.

• Review PHP session-cookie settings and retest the issued cookies.

Evidence screenshots:

```
intern@ubunto:~$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Start Time:         2026-11-14 21:07:46 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Cookie security created without the httponly flag
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server leaks inodes via ETags, header found with file /DVWA/robots.txt, fields: 0x19 0x66013b329f96c
+ File/dir '/' in robots.txt returned a non-forbidden or redirect HTTP code (302)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3268: /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ OSVDB-3268: /DVWA/tests/: Directory indexing found.
+ OSVDB-3092: /DVWA/tests/: This might be interesting...
+ OSVDB-3268: /DVWA/database/: Directory indexing found.
+ OSVDB-3093: /DVWA/database/: Databases? Really??
+ OSVDB-3268: /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ OSVDB-3092: /DVWA/.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 16 item(s) reported on remote host
+ End Time:           2026-11-14 21:07:53 (GMT5) (7 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Nikto output reporting missing HttpOnly attributes.

```
intern@ubunto:~$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Start Time:         2026-11-14 21:07:46 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Cookie security created without the httponly flag
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server leaks inodes via ETags, header found with file /DVWA/robots.txt, fields: 0x19 0x66013b329f96c
+ File/dir '/' in robots.txt returned a non-forbidden or redirect HTTP code (302)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3268: /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ OSVDB-3268: /DVWA/tests/: Directory indexing found.
+ OSVDB-3092: /DVWA/tests/: This might be interesting...
+ OSVDB-3268: /DVWA/database/: Directory indexing found.
+ OSVDB-3093: /DVWA/database/: Databases? Really??
+ OSVDB-3268: /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ OSVDB-3092: /DVWA/.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 16 item(s) reported on remote host
+ End Time:           2026-11-14 21:07:53 (GMT5) (7 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Nikto scan output containing cookie observations.

VA-07 — Missing Anti-Clickjacking Header

Suggested severity: Low **HTTP response headers**

Description and test result: Nikto reported that the X-Frame-Options response header was absent. This header can restrict framing; Content-Security-Policy frame-ancestors is the modern policy mechanism.

Potential impact: Potential impact: without a framing policy, a malicious site may embed the application and attempt to trick a user into clicking controls.

Recommended remediation:

• Set Content-Security-Policy: frame-ancestors with an appropriate policy.

• For legacy support, consider X-Frame-Options: SAMEORIGIN or DENY.

• Retest response headers after configuration.

Evidence screenshots:

```
intern@ubunto:~$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Start Time:         2026-11-14 21:07:46 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Cookie security created without the httponly flag
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server leaks inodes via ETags, header found with file /DVWA/robots.txt, fields: 0x19 0x66013b329f96c
+ File/dir '/' in robots.txt returned a non-forbidden or redirect HTTP code (302)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3268: /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ OSVDB-3268: /DVWA/tests/: Directory indexing found.
+ OSVDB-3092: /DVWA/tests/: This might be interesting...
+ OSVDB-3268: /DVWA/database/: Directory indexing found.
+ OSVDB-3093: /DVWA/database/: Databases? Really??
+ OSVDB-3268: /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ OSVDB-3092: /DVWA/.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 16 item(s) reported on remote host
+ End Time:           2026-11-14 21:07:53 (GMT5) (7 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Nikto output reporting missing X-Frame-Options.

```
intern@ubunto:~$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Start Time:         2026-11-14 21:07:46 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Cookie security created without the httponly flag
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server leaks inodes via ETags, header found with file /DVWA/robots.txt, fields: 0x19 0x66013b329f96c
+ File/dir '/' in robots.txt returned a non-forbidden or redirect HTTP code (302)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3268: /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ OSVDB-3268: /DVWA/tests/: Directory indexing found.
+ OSVDB-3092: /DVWA/tests/: This might be interesting...
+ OSVDB-3268: /DVWA/database/: Directory indexing found.
+ OSVDB-3093: /DVWA/database/: Databases? Really??
+ OSVDB-3268: /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ OSVDB-3092: /DVWA/.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 16 item(s) reported on remote host
+ End Time:           2026-11-14 21:07:53 (GMT5) (7 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Nikto scan output showing the header observation.

VA-08 — Server Banner and ETag Information Disclosure

Suggested severity: Low / Informational **Apache response metadata**

Description and test result: Nikto identified the server banner as Apache/2.4.52 (Ubuntu) and reported ETag inode disclosure. These observations reveal implementation and file metadata but do not, by themselves, prove that the server can be compromised.

Potential impact: Potential impact: technology and metadata disclosure may help an attacker select follow-up techniques; no compromise was demonstrated from these observations alone.

Recommended remediation:

• Reduce unnecessary server-token and server-signature disclosure.

• Review ETag settings and disable inode disclosure where appropriate.

• Keep Apache and related packages patched.

• Retest response headers and ETag behavior.

Evidence screenshots:

```
intern@ubunto:~$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Start Time:         2026-11-14 21:07:46 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Cookie security created without the httponly flag
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server leaks inodes via ETags, header found with file /DVWA/robots.txt, fields: 0x19 0x66013b329f96c
+ File/dir '/' in robots.txt returned a non-forbidden or redirect HTTP code (302)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3268: /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ OSVDB-3268: /DVWA/tests/: Directory indexing found.
+ OSVDB-3092: /DVWA/tests/: This might be interesting...
+ OSVDB-3268: /DVWA/database/: Directory indexing found.
+ OSVDB-3093: /DVWA/database/: Databases? Really??
+ OSVDB-3268: /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ OSVDB-3092: /DVWA/.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 16 item(s) reported on remote host
+ End Time:           2026-11-14 21:07:53 (GMT5) (7 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Nikto server banner and ETag observations.


```
intern@ubunto:~$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Start Time:         2026-11-14 21:07:46 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Cookie security created without the httponly flag
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server leaks inodes via ETags, header found with file /DVWA/robots.txt, fields: 0x19 0x66013b329f96c
+ File/dir '/' in robots.txt returned a non-forbidden or redirect HTTP code (302)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3268: /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ OSVDB-3268: /DVWA/tests/: Directory indexing found.
+ OSVDB-3092: /DVWA/tests/: This might be interesting...
+ OSVDB-3268: /DVWA/database/: Directory indexing found.
+ OSVDB-3093: /DVWA/database/: Databases? Really??
+ OSVDB-3268: /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ OSVDB-3092: /DVWA/.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 16 item(s) reported on remote host
+ End Time:           2026-11-14 21:07:53 (GMT5) (7 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```


Full Nikto scan output.

6. Nikto Automated Assessment

Nikto 2.1.5 was installed and verified. The scan command was `nikto -h http://127.0.0.1/DVWA/`. The captured scan reported 6,544 items checked, zero scanner errors and 16 reported items. These are scanner observations, not 16 independently confirmed exploitable vulnerabilities.

• Missing HttpOnly flag on security and PHPSESSID cookies.

• X-Frame-Options header absent.

• Apache/2.4.52 (Ubuntu) server banner disclosed.

• ETag inode information reported.

• Directory indexing reported for config, tests, database and docs paths.

• A Git index path was reported by the scanner and should be investigated/blocked.

```
intern@ubunto:~$ nikto -Version
Command 'nikto' not found, but can be installed with:
sudo apt install nikto
intern@ubunto:~$ sudo apt install nikto -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  libwhisker2-perl
The following NEW packages will be installed:
  libwhisker2-perl nikto
0 upgraded, 2 newly installed, 0 to remove and 464 not upgraded.
Need to get 344 kB of archives.
After this operation, 2,207 kB of additional disk space will be used.
```

Installing Nikto on the Ubuntu VM.

```
intern@ubunto:~$ nikto -Version
---------------------------------------------------------------------------
Nikto Versions
---------------------------------------------------------------------------
File                              Version      Last Mod
-----------------------------     --------     ----------
Nikto main                        2.1.5
LibWhisker                        2.5
CHANGES.txt
db_404_strings                    2.003
db_content_search                 2.000
         2012-07-04               1.0
db_embedded                       2.004
db_favicon                        2.010
```

Nikto version verification: 2.1.5.

```
intern@ubunto:~$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Start Time:         2026-11-14 21:07:46 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Cookie security created without the httponly flag
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server leaks inodes via ETags, header found with file /DVWA/robots.txt, fields: 0x19 0x66013b329f96c
+ File/dir '/' in robots.txt returned a non-forbidden or redirect HTTP code (302)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3268: /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ OSVDB-3268: /DVWA/tests/: Directory indexing found.
+ OSVDB-3092: /DVWA/tests/: This might be interesting...
+ OSVDB-3268: /DVWA/database/: Directory indexing found.
+ OSVDB-3093: /DVWA/database/: Databases? Really??
+ OSVDB-3268: /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ OSVDB-3092: /DVWA/.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 16 item(s) reported on remote host
+ End Time:           2026-11-14 21:07:53 (GMT5) (7 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Nikto scan output against the local DVWA target.

```
intern@ubunto:~$ nikto -Version
---------------------------------------------------------------------------
Nikto Versions
---------------------------------------------------------------------------
File                              Version      Last Mod
-------------------------------   --------     ----------
Nikto main                        2.1.5
LibWhisker                        2.5
CHANGES.txt
db_404_strings                    2.003
db_content_search                 2.000
         2012-07-04               1.0
db_embedded                       2.004
db_favicon                        2.010
```

Additional Nikto version output.

```
intern@ubunto:~$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    localhost
+ Target Port:        80
+ Start Time:         2026-11-14 21:07:46 (GMT5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.52 (Ubuntu)
+ Cookie security created without the httponly flag
+ Cookie PHPSESSID created without the httponly flag
+ The anti-clickjacking X-Frame-Options header is not present.
+ Root page / redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Server leaks inodes via ETags, header found with file /DVWA/robots.txt, fields: 0x19 0x66013b329f96c
+ File/dir '/' in robots.txt returned a non-forbidden or redirect HTTP code (302)
+ "robots.txt" contains 1 entry which should be manually viewed.
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD
+ OSVDB-3268: /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ OSVDB-3268: /DVWA/tests/: Directory indexing found.
+ OSVDB-3092: /DVWA/tests/: This might be interesting...
+ OSVDB-3268: /DVWA/database/: Directory indexing found.
+ OSVDB-3093: /DVWA/database/: Databases? Really??
+ OSVDB-3268: /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ OSVDB-3092: /DVWA/.git/index: Git Index file may contain directory listing information.
+ 6544 items checked: 0 error(s) and 16 item(s) reported on remote host
+ End Time:           2026-11-14 21:07:53 (GMT5) (7 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Full scan output and reported observations.

7. Remediation Performed and Verification

The confirmed remediation in this assessment was disabling directory indexing for the DVWA directory. The Apache configuration used:

```
<Directory /var/www/html/DVWA>
    Options -Indexes
</Directory>
```

The configuration was checked with apache2ctl configtest. Apache displayed an AH00558 ServerName warning, but the test also returned **Syntax OK**. A browser retest of /DVWA/config/ returned **403 Forbidden**. This verifies the tested path only; all other scanner-reported directories and direct file URLs still need testing.

8. Prioritized Recommendations

• Priority 1: Fix SQL Injection using parameterized queries and fix both XSS paths using context-aware output encoding.

• Priority 2: Replace predictable session identifiers with cryptographically secure tokens and review session lifecycle controls.

• Priority 3: Apply HttpOnly, Secure (over HTTPS) and SameSite cookie attributes as appropriate.

• Priority 4: Add a framing policy using Content-Security-Policy frame-ancestors and, if needed, X-Frame-Options.

• Priority 5: Disable directory indexing, block direct access to sensitive files and investigate the reported .git path.

• Priority 6: Reduce unnecessary server/ETag disclosure and keep the web server patched.

• Retest all findings after changes and preserve before/after evidence.

9. Limitations and Interpretation

This was a training-lab assessment against DVWA configured at Low security. Findings apply to the intentionally vulnerable application and local server configuration. No production environment, external network or third-party service was tested. The dvwaSession sequence does not establish compromise of PHPSESSID or account takeover. Nikto observations require individual validation. Directory indexing was verified as fixed only for /DVWA/config/.

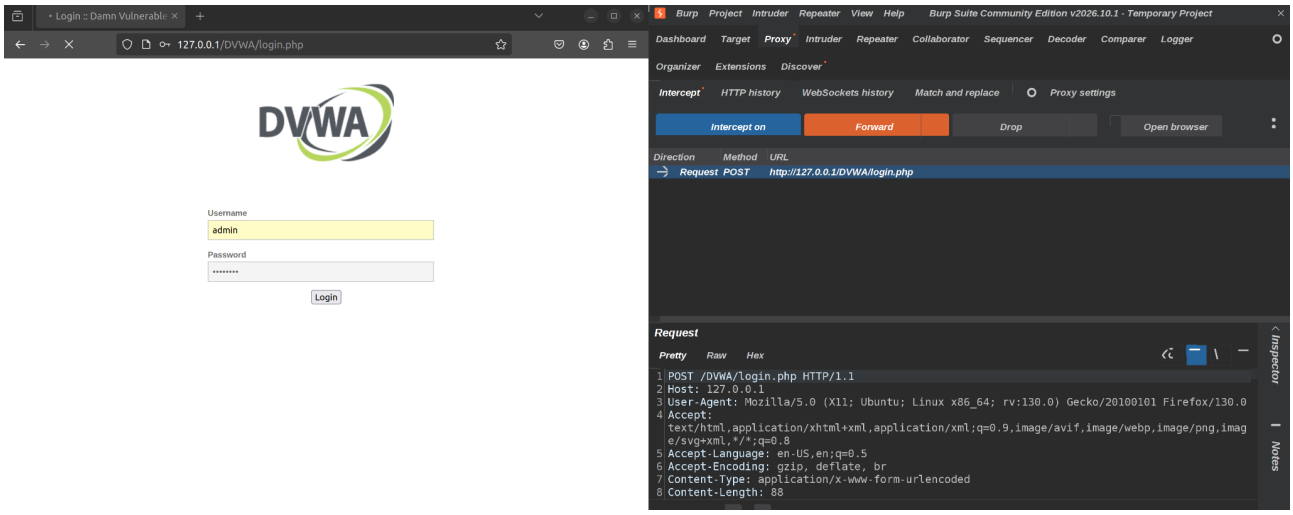
Severity ratings are qualitative and provisional, not a formal CVSS score set. A production assessment would additionally require business context, authentication and authorization analysis, exploitability validation, and a documented risk-acceptance process.

10. Conclusion

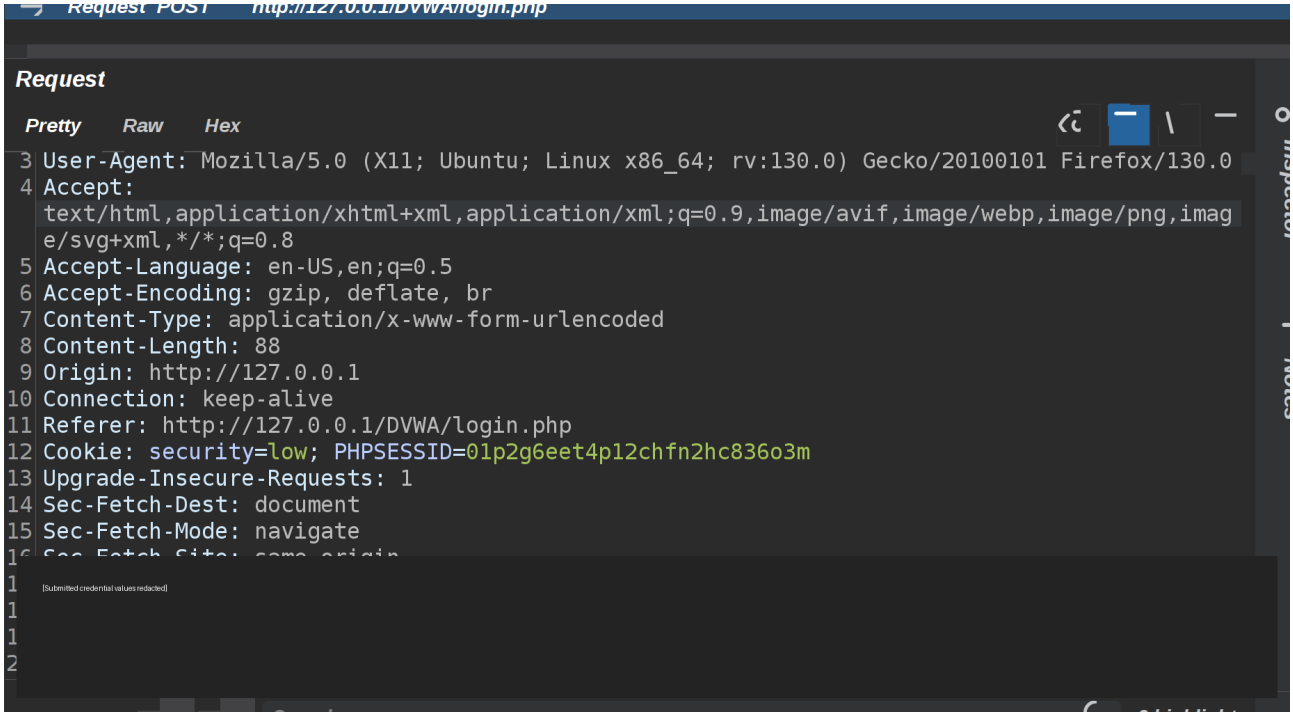
The assessment demonstrated four DVWA application test cases and identified several web-server configuration weaknesses. Directory indexing was disabled and verified for the tested configuration path. The most important next steps are to remediate injection and XSS issues, strengthen session management, apply secure cookie and framing headers, investigate exposed development artifacts, and conduct a complete retest.

Appendix — Additional Evidence

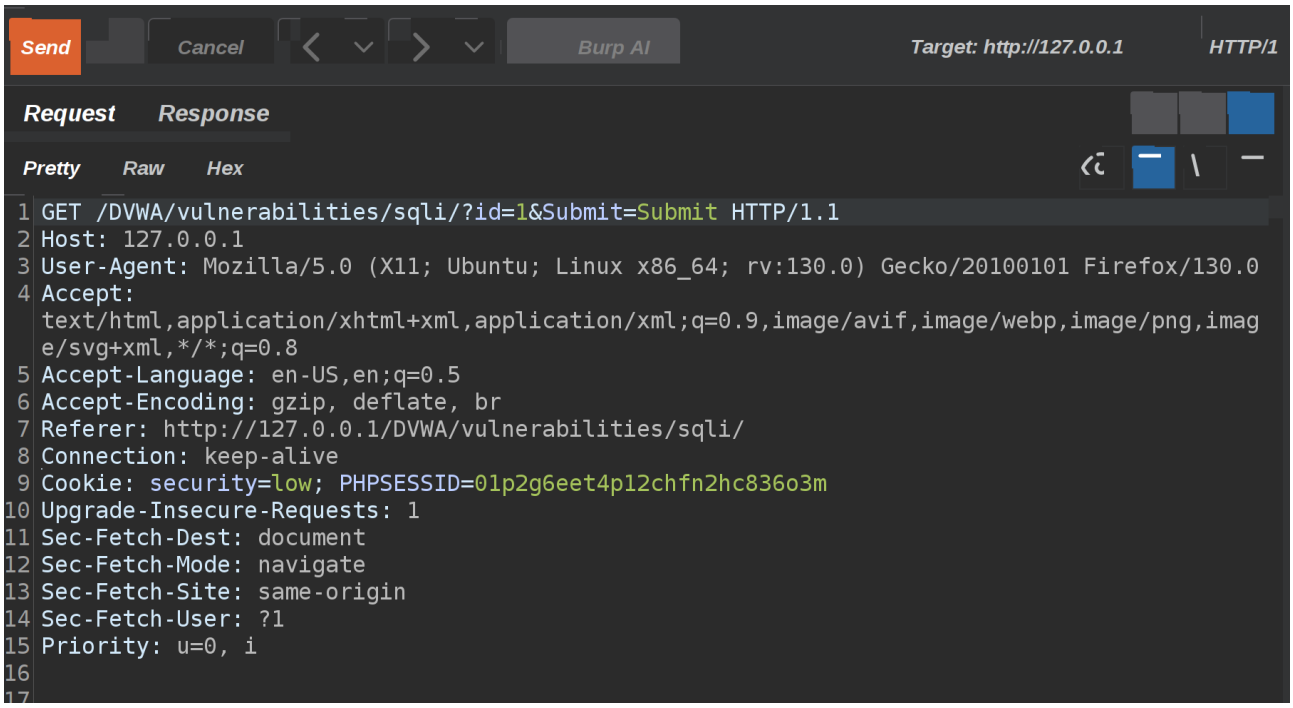
Additional screenshots supplied during the assessment are included below to preserve the complete evidence set. Screenshots already used in the detailed findings are not duplicated here.



Additional supporting evidence: 1 Capturing login page req.png



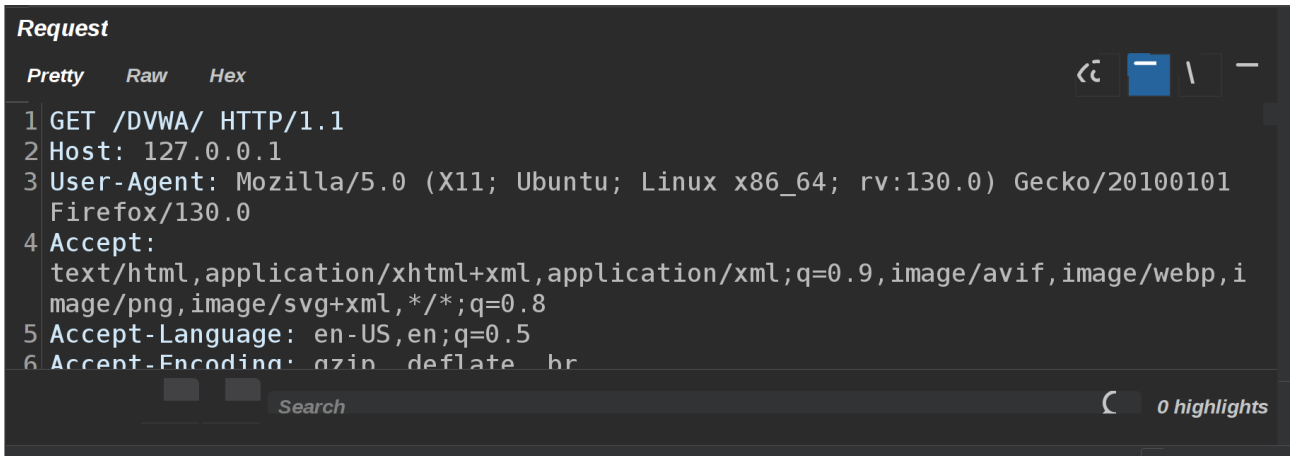
Additional supporting evidence: 2 Sensitive Data Exposure in Req Body.png



Additional supporting evidence: 2 Simple req in repeater.png



Additional supporting evidence: 3 Using Post Method.png



Additional supporting evidence: 6 Request.png

Task 2: Conduct OWASP Top 10 testing on the vulnerable application - 2 days

Using the lab you built, perform manual and automated tests covering at least five OWASP Top 10 categories (e.g., Injection, Broken Authentication, XSS, Security Misconfiguration, Sensitive Data Exposure). Record each finding, assign a CVSS 3.1 base score, and suggest a concrete fix. The output will become the core of the client's security assessment.

How to do it:

1. Launch Burp Suite Community Edition and configure it to proxy the DVWA site
2. Test for SQL injection, XSS, and insecure direct object references using Burp and manual payloads
3. Run OWASP ZAP or nikto for automated checks of other categories
4. Document each successful test with request/response details and calculate CVSS scores
5. Compile all findings into a single Markdown assessment report

Tools you will use: Burp Suite Community, OWASP ZAP, Nikto, CVSS calculator, Git

What it looks like when done:
A professional-looking assessment report that a client executive could read, showing clear risk ratings and actionable fixes for each OWASP issue.

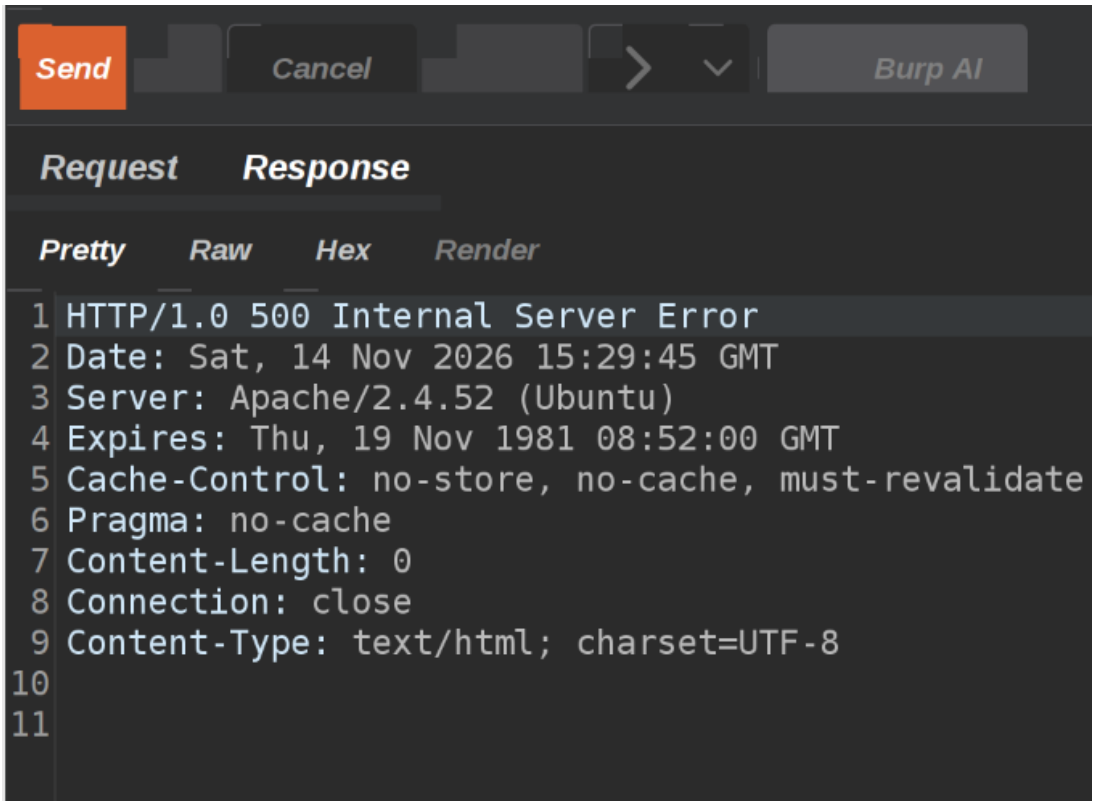
See real examples (open the link, look at a few, then make your own - never copy one):
- https://www.google.com/search?tbm=isch&q=OWASP%20Top%2010%20DVWA%20testing%20guide
- https://github.com/search?type=repositories&q=OWASP%20Top%2010%20DVWA%20testing%20guide

What your mentor will check

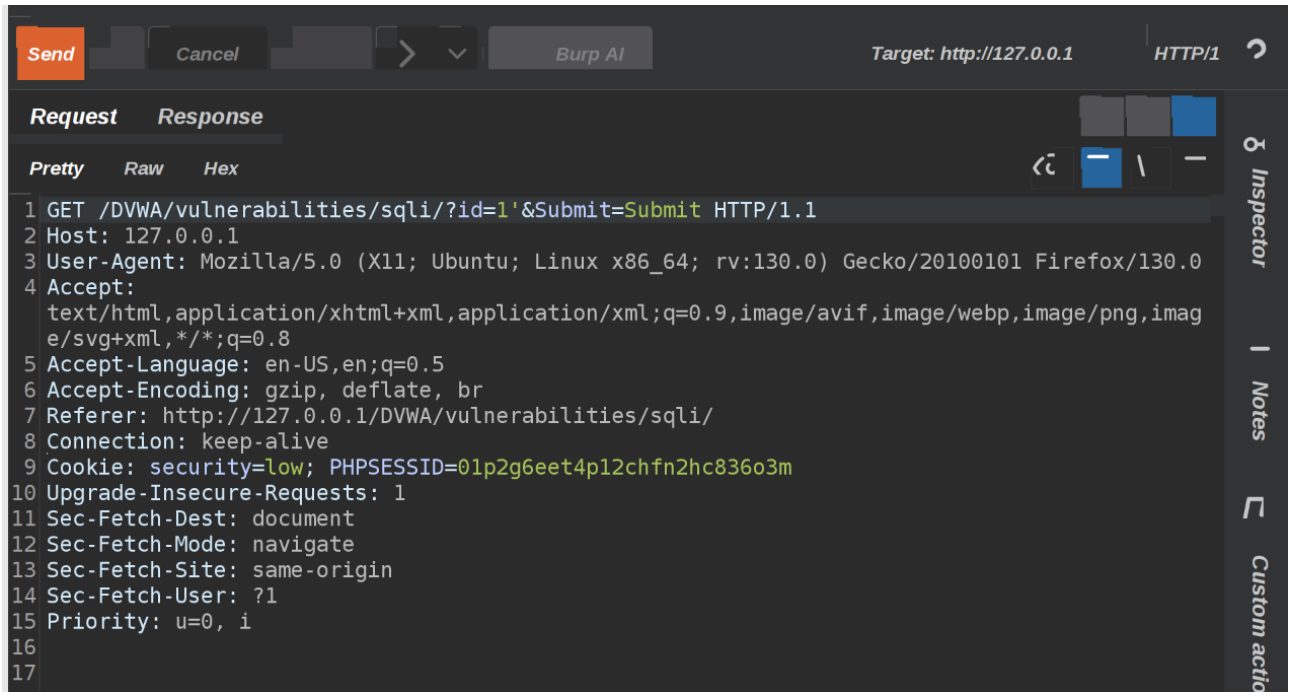
- Assessment report lists at least five distinct OWASP findings with CVSS scores
- Each finding includes a proof-of-concept (command, request, or screenshot) and a remediation recommendation
- Report is formatted in Markdown and linked from the repository's root

Skills: OWASP testing, Burp Suite Community, manual exploitation, CVSS scoring
Submit: a GitHub repository with a README, plus a short note on what you did and why.

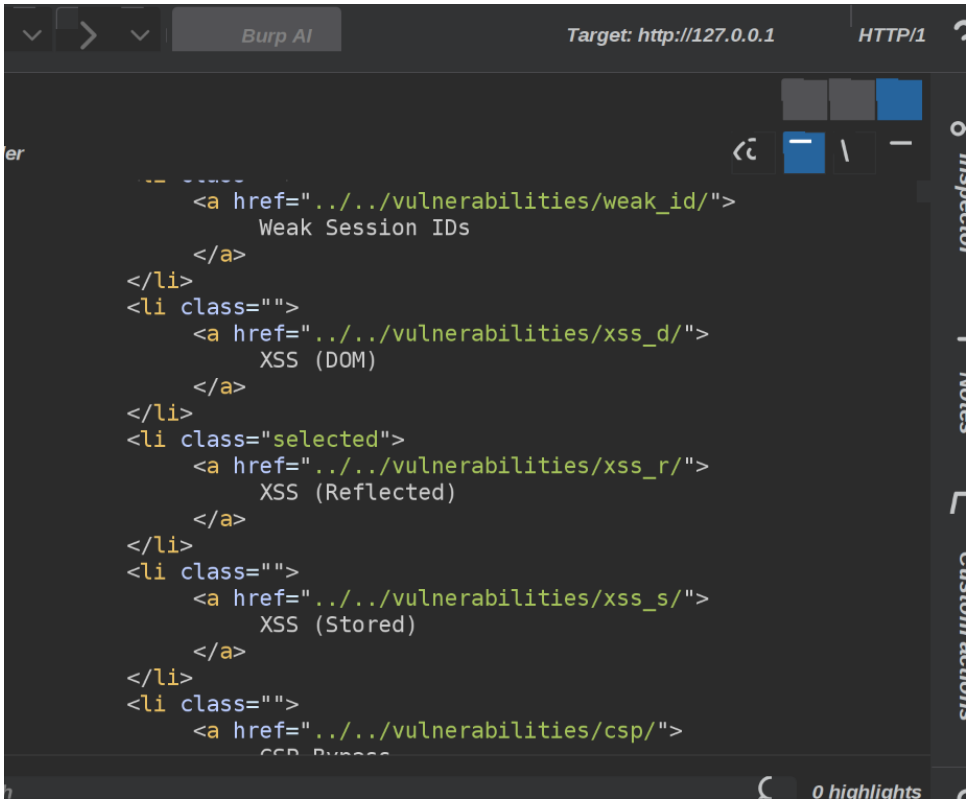
Additional supporting evidence: image(20261114-145354).png



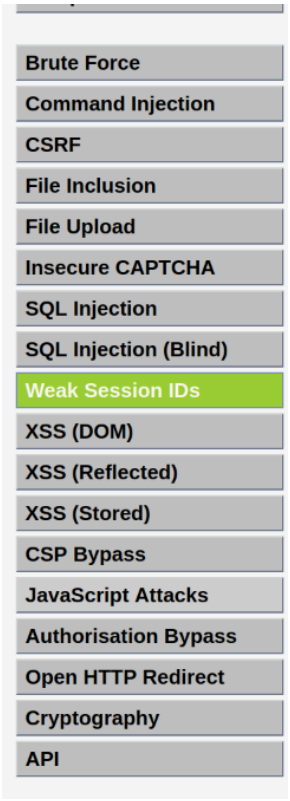
Additional supporting evidence: image(20261114-153018).png



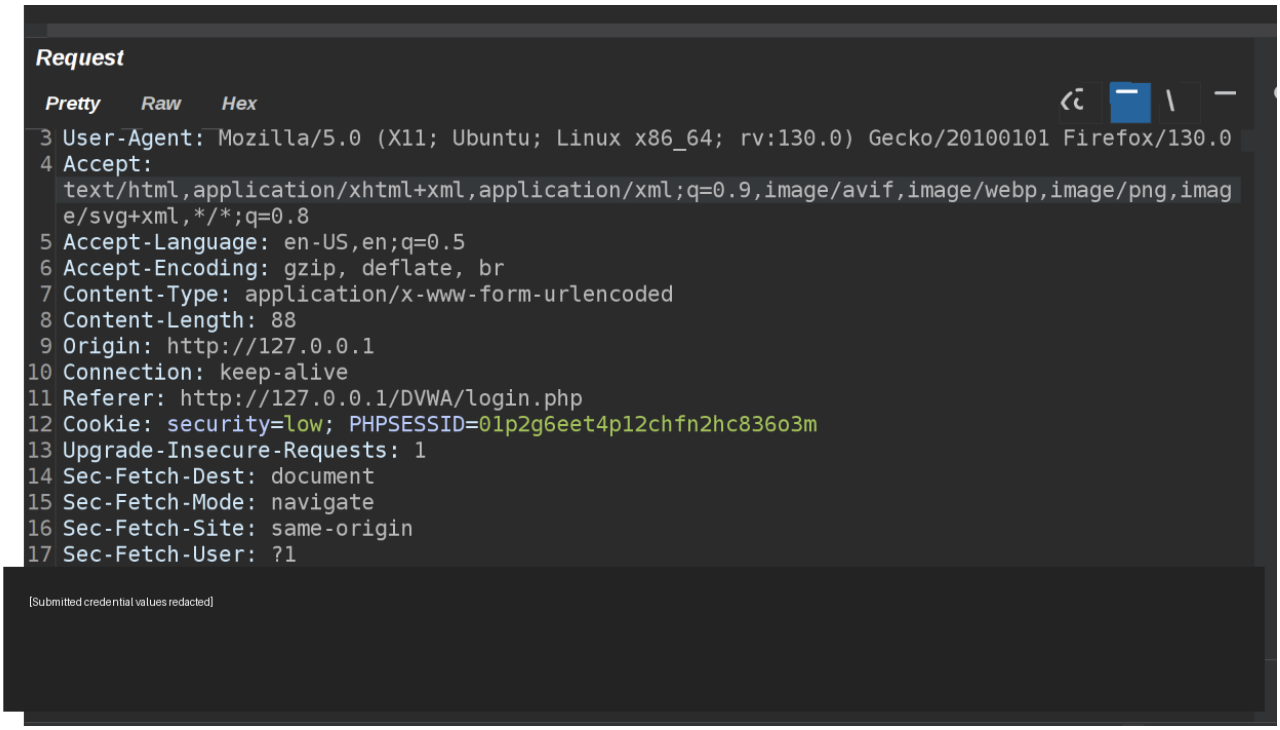
Additional supporting evidence: image(20261114-153101).png



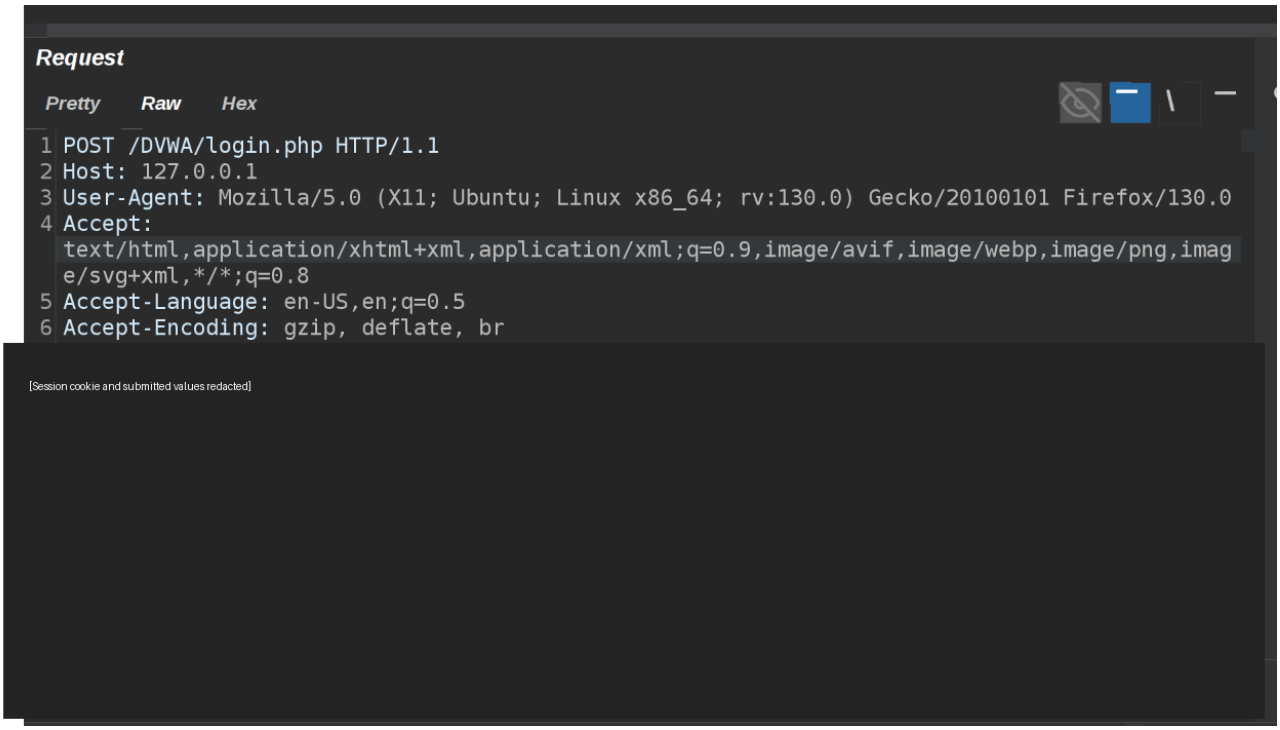
Additional supporting evidence: image(20261114-154423).png



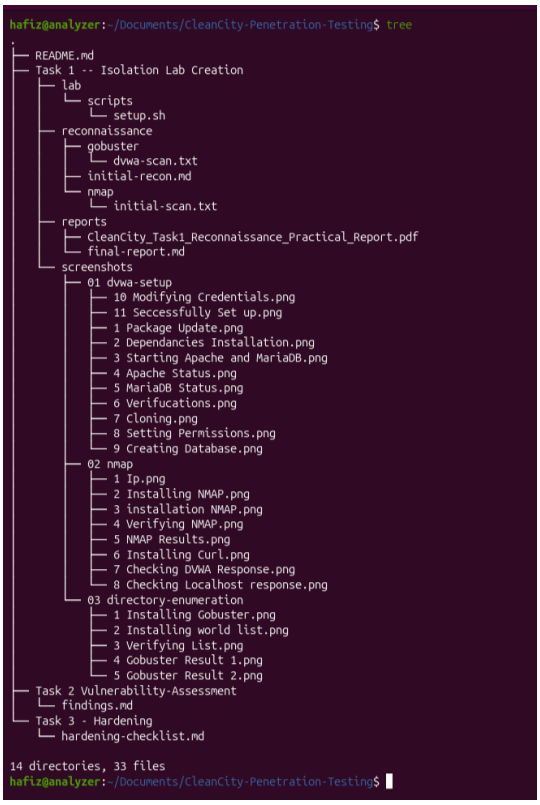
Additional supporting evidence: image(20261114-155517).png



Additional supporting evidence: image(20261114-162026).png



Additional supporting evidence: image(20261114-162127).png



Additional supporting evidence: image(20261114-164437).png